



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

POLÍTICAS DE SEGURIDAD DE LA INFORMACIÓN

PROCEDIMIENTOS DE IMPLEMENTACIÓN



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General



ÍNDICE

1. INTRODUCCIÓN

2. CLASIFICACIÓN Y CONTROL DE ACTIVOS

- 2.1. Inventario de activos
- 2.2. Clasificación de la información
- 2.3. Rotulado de la Información

3. SEGURIDAD DEL PERSONAL

- 3.1. Seguridad en la Definición de Puestos de Trabajo y la Asignación de Recursos
 - 3.1.1. Incorporación de la Seguridad en los Puestos de Trabajo
 - 3.1.2. Control y Política del Personal
 - 3.1.3. Compromiso de Confidencialidad
 - 3.1.4. Términos y Condiciones de Empleo
- 3.2. Capacitación del Usuario
 - 3.2.1. Formación y Capacitación en Materia de Seguridad de la Información
- 3.3. Respuesta a Incidentes y Anomalías en Materia de Seguridad
 - 3.3.1. Comunicación de Incidentes Relativos a la Seguridad
 - 3.3.2. Comunicación de Debilidades en Materia de Seguridad
 - 3.3.3. Comunicación de Anomalías del Software
 - 3.3.4. Aprendiendo de los Incidentes

4. SEGURIDAD FÍSICA Y AMBIENTAL

- 4.1. Perímetro de Seguridad Física
- 4.2. Controles de Acceso Físico
- 4.3. Protección de Oficinas, Recintos e Instalaciones
- 4.4. Desarrollo de Tareas en Áreas Protegidas
- 4.5. Aislamiento de las Áreas de Recepción y Distribución
- 4.6. Ubicación y Protección del Equipamiento y Copias de Seguridad
- 4.7. Suministros de Energía
- 4.8. Seguridad del Cableado
- 4.9. Mantenimiento de Equipos
- 4.10. Seguridad de los Equipos Fuera de las Instalaciones
- 4.11. Desafectación o Reutilización Segura de los Equipos.
- 4.12. Políticas de Escritorios y Pantallas Limpias
- 4.13. Retiro de los Bienes



Comité de Seguridad de la Información
Coordinación General

5. GESTIÓN DE COMUNICACIONES Y OPERACIONES

- 5.1. Procedimientos y Responsabilidades Operativas
 - 5.1.1. Documentación de los Procedimientos Operativos
 - 5.1.2. Control de Cambios en las Operaciones
 - 5.1.3. Procedimientos de Manejo de Incidentes
 - 5.1.4. Separación de Funciones
 - 5.1.5. Separación entre Instalaciones de Desarrollo e Instalaciones Operativas
 - 5.1.6. Gestión de Instalaciones Externas
- 5.2. Planificación y Aprobación de Sistemas
 - 5.2.1. Planificación de la Capacidad
 - 5.2.2. Aprobación del Sistema
- 5.3. Protección Contra Software Malicioso
 - 5.3.1. Controles Contra Software Malicioso
- 5.4. Mantenimiento
 - 5.4.1. Resguardo de la Información
 - 5.4.2. Registro de Actividades del Personal Operativo
 - 5.4.3. Registro de Fallas
- 5.5. Administración de la Red
 - 5.5.1. Controles de Redes
- 5.6. Administración y Seguridad de los Medios de Almacenamiento
 - 5.6.1. Administración de Medios Informáticos Removibles
 - 5.6.2. Eliminación de Medios de Información
 - 5.6.3. Procedimientos de Manejo de la Información
 - 5.6.4. Seguridad de la Documentación del Sistema
- 5.7. Intercambios de Información y Software
 - 5.7.1. Acuerdos de Intercambio de Información y Software
 - 5.7.2. Seguridad de los Medios en Tránsito
 - 5.7.3. Seguridad del Gobierno Electrónico
 - 5.7.4. Seguridad del Correo Electrónico
 - 5.7.4.1. Riesgos de Seguridad
 - 5.7.4.2. Política de Correo Electrónico
 - 5.7.5. Seguridad de los Sistemas Electrónicos de Oficina
 - 5.7.6. Sistemas de Acceso Público
 - 5.7.7. Otras Formas de Intercambio de Información

6. CONTROL DE ACCESOS

- 6.1. Requerimientos para el Control de Acceso
 - 6.1.1. Política de Control de Accesos
 - 6.1.2. Reglas de Control de Acceso
- 6.2. Administración de Accesos de Usuarios



Comité de Seguridad de la Información

Coordinación General

- 6.2.1. Registración de Usuarios
- 6.2.2. Administración de Privilegios
- 6.2.3. Administración de Contraseñas de Usuario
- 6.2.4. Administración de Contraseñas Críticas
- 6.2.5. Revisión de Derechos de Acceso de Usuarios
- 6.3. Responsabilidades del Usuario
 - 6.3.1. Uso de Contraseñas
 - 6.3.2. Equipos Desatendidos en Áreas de Usuarios
- 6.4. Control de Acceso a la Red
 - 6.4.1. Política de Utilización de los Servicios de Red
 - 6.4.2. Camino Forzado
 - 6.4.3. Autenticación de Usuarios para Conexiones Externas
 - 6.4.4. Autenticación de Nodos
 - 6.4.5. Protección de los Puertos (Ports) de Diagnóstico Remoto
 - 6.4.6. Subdivisión de Redes
 - 6.4.7. Acceso a Internet
 - 6.4.8. Control de Conexión a la Red
 - 6.4.9. Control de Ruteo de Red
 - 6.4.10. Seguridad de los Servicios de Red
- 6.5. Control de Acceso al Sistema Operativo
 - 6.5.1. Identificación Automática de Terminales
 - 6.5.2. Procedimientos de Conexión de Terminales
 - 6.5.3. Identificación y Autenticación de los Usuarios
 - 6.5.4. Sistema de Administración de Contraseñas
 - 6.5.5. Uso de Utilitarios de Sistema
 - 6.5.6. Alarmas Silenciosas para la Protección de los Usuarios
 - 6.5.7. Desconexión de Terminales por Tiempo Muerto
 - 6.5.8. Limitación del Horario de Conexión
- 6.6. Control de Acceso a las Aplicaciones
 - 6.6.1. Restricción del Acceso a la Información
 - 6.6.2. Aislamiento de los Sistemas Sensibles
- 6.7. Monitoreo del Acceso y Uso de los Sistemas
 - 6.7.1. Registro de Eventos
 - 6.7.2. Monitoreo del Uso de los Sistemas
 - 6.7.2.1. Procedimientos y Áreas de Riesgo
 - 6.7.2.2. Factores de Riesgo
 - 6.7.2.3. Registro y Revisión de Eventos
 - 6.7.3. Sincronización de Relojes
- 6.8. Computación Móvil y Trabajo Remoto
 - 6.8.1. Computación Móvil
 - 6.8.2. Trabajo Remoto



Comité de Seguridad de la Información
Coordinación General

7. DESARROLLO Y MANTENIMIENTO DE SISTEMAS

- 7.1. Requerimientos de Seguridad de los Sistemas
 - 7.1.1. Análisis y Especificaciones de los Requerimientos de Seguridad
- 7.2. Seguridad en los Sistemas de Aplicación
 - 7.2.1. Validación de Datos de Entrada
 - 7.2.2. Controles de Procesamiento Interno
 - 7.2.3. Autenticación de Mensajes
 - 7.2.4. Validación de Datos de Salidas
- 7.3. Controles Criptográficos
 - 7.3.1. Política de Utilización de Controles Criptográficos
 - 7.3.2. Cifrado
 - 7.3.3. Firma Digital
 - 7.3.4. Servicios de No Repudio
 - 7.3.5. Administración de Claves
 - 7.3.5.1. Protección de Claves Criptográficas
- 7.4. Seguridad de los Archivos del Sistema
 - 7.4.1. Control del Software Operativo
 - 7.4.2. Protección de los Datos de Prueba del Sistema
 - 7.4.3. Control de Cambios a Datos Operativos
 - 7.4.4. Control de Acceso a las Bibliotecas de Programas Fuentes
- 7.5. Seguridad de los Procesos de Desarrollo y Soporte
 - 7.5.1. Procedimiento de Control de Cambios
 - 7.5.2. Revisión Técnica de los Cambios en el Sistema Operativo
 - 7.5.3. Restricción del Cambio de Paquetes de Software
 - 7.5.4. Canales Ocultos y Código Malicioso
 - 7.5.5. Desarrollo Externo de Software

8. ADMINISTRACIÓN DE LA CONTINUIDAD DE LAS ACTIVIDADES

- 8.1. Proceso de la Administración de la Continuidad del Organismo
- 8.2. Continuidad de las Actividades y Análisis de los Impactos
- 8.3. Elaboración e Implementación de los Planes de Continuidad de las Actividades de la Universidad
- 8.4. Marco para la Planificación de la Continuidad de las Actividades de la Universidad
- 8.5. Ensayo, Mantenimiento y Reevaluación de los Planes de Continuidad de la Universidad



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información Coordinación General

INTRODUCCIÓN

Este documento describe los procedimientos que posibilitan la implementación del Plan de Seguridad de la Información de la Universidad Tecnológica Nacional, de acuerdo con el Modelo elaborado por la Oficina Nacional de Tecnología de Información ONTI para los Organismos de la Administración Pública Nacional. Conjuntamente con los anteriores documentos elaborados en este año por el Comité de Seguridad de la Información de la Universidad Tecnológica Nacional (Políticas de Seguridad de la Información y Plan de Acción 2009), establece los elementos teórico-prácticos para encarar dicho Plan, de acuerdo a las modalidades y prioridades que fije la autoridad de aplicación a tal efecto.

Con el objeto de precisar las responsabilidades que caben a los distintos áreas de la Universidad participantes de los procedimientos, y siguiendo las definiciones realizadas por la ONTI en este aspecto, se han identificado en el presente documento los siguientes roles:

a) El Responsable del Área de Recursos Humanos:

- Funciones relativas a la seguridad de la información en las descripciones de puestos de los empleados,
- Información al personal que ingresa, de sus obligaciones respecto del cumplimiento de la Política de Seguridad de la Información,
- Gestión de los Compromisos de Confidencialidad con el personal y
- Coordinación las tareas de capacitación de usuarios respecto de dicha Política.

b) El Responsable de Seguridad Informática:

- Seguimiento, documentación y análisis de los incidentes de seguridad reportados así como su comunicación al Comité de Seguridad de la Información, a los propietarios de la información y a la Coordinación de Emergencias en Redes Teleinformáticas (ArCERT).

c) El Comité de Seguridad de la Información:

- Responsable de implementar los medios y canales necesarios para que el Responsable de Seguridad Informática maneje los reportes de incidentes y anomalías de los sistemas. Asimismo, dicho Comité, tomará conocimiento, efectuará el seguimiento de la investigación, controlará la evolución e impulsará la resolución de los incidentes a la seguridad.

d) El Responsable del Área Legal:

- La confección del Compromiso de Confidencialidad a firmar por los empleados y terceros que desarrollen funciones en la Universidad,
- En el asesoramiento sobre las sanciones a ser aplicadas por incumplimiento de la presente Política y
- En el tratamiento de incidentes de seguridad que requieran de su intervención.



Comité de Seguridad de la Información

Coordinación General

Las funciones de los siguientes roles están definidas en los acápites que acompañan a cada definición:

- e) Responsable de Unidad Organizativa (ver 2.1)**
- f) Áreas Responsables del Material de Capacitación (ver 3.2.1)**
- g) Responsable del Área Informática (ver 5)**
- h) Administrador de Programas Fuentes (ver 7.4.4.)**
- i) Administradores de Planes de contingencia (ver 8.4)**

Sin perjuicio de estas responsabilidades específicas, todo el personal de la Universidad es responsable del reporte de debilidades e incidentes de seguridad que oportunamente se detecten.

CLASIFICACIÓN Y CONTROL DE ACTIVOS

2.1. Inventario de activos

Deberían identificarse los activos importantes asociados a cada sistema de información, sus respectivos propietarios y su ubicación, para luego elaborar un inventario con dicha información. El mismo debería ser actualizado ante cualquier modificación de la información registrada y revisado con una periodicidad no mayor a 6 meses.

El encargado de elaborar el inventario y mantenerlo actualizado debería ser cada Responsable de Unidad Organizativa.

2.2. Clasificación de la Información

Se debería evaluar y definir la información de acuerdo a las tres características en la cuales se basa la seguridad:

a) Confidencialidad:

0- Información que puede ser conocida y utilizada sin autorización por cualquier persona, sea empleado del Organismo o no. PUBLICO.

1- Información que puede ser conocida y utilizada por todos los empleados de la Universidad y algunas entidades externas debidamente autorizadas, y cuya divulgación o uso no autorizados podría ocasionar riesgos o pérdidas leves para el Organismo, el Sector Público Nacional o terceros. RESERVADA – USO INTERNO

2- Información que sólo puede ser conocida y utilizada por un grupo de empleados, que la necesiten para realizar su trabajo, y cuya divulgación o uso no autorizados podría ocasionar pérdidas significativas a la Universidad, al Sector Público Nacional o a terceros. RESERVADA - CONFIDENCIAL

3- Información que sólo puede ser conocida y utilizada por un grupo muy reducido de



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

empleados, generalmente de la alta dirección de la Universidad, y cuya divulgación o uso no autorizados podría ocasionar pérdidas graves al mismo, al Sector Público Nacional o a terceros. RESERVADA SECRETA

b) Integridad:

0- Información cuya modificación no autorizada puede repararse fácilmente, o no afecta la operatoria de la Universidad.

1- Información cuya modificación no autorizada puede repararse aunque podría ocasionar pérdidas leves para la Universidad, el Sector Público Nacional o terceros.

2- Información cuya modificación no autorizada es de difícil reparación y podría ocasionar pérdidas significativas para la Universidad, el Sector Público Nacional o terceros.

3- Información cuya modificación no autorizada no podría repararse, ocasionando pérdidas graves a la Universidad, al Sector Público Nacional o a terceros.

c) Disponibilidad

2.3. Rotulado de la Información

Se deberían rotular los recursos de información tanto en formatos físicos como electrónicos e incorporar las siguientes actividades de procesamiento de la información:

- * Copia
- * Almacenamiento
- * Transmisión por correo, fax, correo electrónico
- * Transmisión oral (telefonía fija y móvil, correo de voz, contestadores automáticos, etc.).

SEGURIDAD DEL PERSONAL

3.1. Seguridad en la Definición de Puestos de Trabajo y la Asignación de Recursos

3.1.1. Incorporación de la Seguridad en los Puestos de Trabajo. Las funciones y responsabilidades en materia de seguridad deberían ser incorporadas en la descripción de las responsabilidades de los puestos de trabajo.

3.1.2. Control y Política del Personal. Deberían llevarse a cabo controles de verificación del personal en el momento en que se solicita el puesto.

3.1.3 Compromiso de Confidencialidad. Se debería desarrollar un procedimiento para la suscripción del Compromiso de Confidencialidad donde se incluirán aspectos sobre:

- a) Suscripción inicial del Compromiso por parte de la totalidad del personal.



Comité de Seguridad de la Información

Coordinación General

b) Revisión del contenido del Compromiso cada año.

c) Método de resuscripción en caso de modificación del texto del Compromiso.

3.1.4. Términos y Condiciones de Empleo. Los términos y condiciones de empleo deberían establecerse la responsabilidad del empleado en materia de seguridad de la información

3.2. Capacitación del Usuario

3.2.1. Formación y Capacitación en Materia de Seguridad de la Información. Se debería coordinar las acciones de capacitación que surjan de la presente Política. En forma periódica debería revisarse el material correspondiente a la capacitación, a fin de evaluar la pertinencia de su actualización, de acuerdo al estado del arte de ese momento. El personal que ingrese a la Universidad debería recibir el material, indicándosele el comportamiento esperado en lo que respecta a la seguridad de la información, antes de serle otorgados los privilegios de acceso a los sistemas que correspondan.

3.3. Respuesta a Incidentes y Anomalías en Materia de Seguridad

3.3.1. Comunicación de Incidentes Relativos a la Seguridad. Sin perjuicio de informar a otros Organismos de competencia, el Responsable de Seguridad Informática, debería comunicar a la Coordinación de Emergencias en Redes Teleinformáticas -ArCERT1 todo incidente o violación de la seguridad, que involucrara recursos informáticos. Todos los empleados y contratistas deberían conocer el procedimiento de comunicación de incidentes de seguridad e informar de los mismos tan pronto hayan tomado conocimiento de su ocurrencia.

3.3.2. Comunicación de Debilidades en Materia de Seguridad. Se debería no permitir a los usuarios la realización de pruebas para detectar y/o utilizar una supuesta debilidad o falla de seguridad.

3.3.3. Comunicación de Anomalías del Software. Se debería proceder de acuerdo al siguiente detalle:

- a) Registrar los síntomas del problema y los mensajes que aparecen en pantalla.
- b) Establecer las medidas de aplicación inmediata ante la presencia de una anomalía.
- c) Alertar inmediatamente al Responsable de Seguridad Informática o del Activo de que se trate.

Se debería no permitir a los usuarios quitar el software que supuestamente tiene una anomalía, a menos que estuviesen autorizados formalmente para hacerlo.

3.3.4. Aprendiendo de los Incidentes. Se debería definir un proceso que permita documentar, cuantificar y monitorear los tipos, volúmenes y costos de los incidentes y anomalías.



Comité de Seguridad de la Información
Coordinación General

SEGURIDAD FISICA Y AMBIENTAL

Se deberían considerar e implementar los siguientes lineamientos y controles, según correspondiese:

- a) Prevenir e impedir accesos no autorizados, daños e interferencia a las sedes, instalaciones e información de la Universidad.
- b) Proteger el equipamiento de procesamiento de información crítica de la Universidad, ubicándolo en áreas protegidas y resguardadas por un perímetro de seguridad definido, con medidas de seguridad y controles de acceso apropiados. Asimismo, contemplar la protección del mismo en su traslado y permanencia fuera de las áreas protegidas, por motivos de mantenimiento u otros.
- c) Controlar los factores ambientales que podrían perjudicar el correcto funcionamiento del equipamiento informático que alberga la información de la Universidad.
- d) Implementar medidas para proteger la información manejada por el personal en las oficinas, en el marco normal de sus labores habituales.
- e) Proporcionar protección proporcional a los riesgos identificados.

El Responsable de Seguridad Informática debería definir, junto con el Responsable del Área Informática y los Propietarios de Información, según corresponda.

4.1. Perímetro de Seguridad Física

Se debería considerar e implementar los siguientes lineamientos y controles, según correspondiese:

- a) Definir y documentar claramente el perímetro de seguridad.
- b) Ubicar las instalaciones de procesamiento de información dentro del perímetro de un edificio o área de construcción físicamente sólida. Las paredes externas del área deberían ser sólidas y todas las puertas que comunican con el exterior deberían estar adecuadamente protegidas contra accesos no autorizados.
- c) Verificar la existencia de un área de recepción atendida por personal. Si esto no fuera posible se deberían implementar otros medios alternativos de control de acceso físico al área o edificio. El acceso a dichas áreas y edificios debería estar restringido exclusivamente al personal autorizado. Los métodos implementados deberían registrar cada ingreso y egreso en forma precisa.
- d) Extender las barreras físicas necesarias desde el piso (real) hasta el techo (real), a fin de impedir el ingreso no autorizado y la contaminación ambiental, por ejemplo por incendio, humedad e inundación.
- e) Identificar claramente todas las puertas de incendio de un perímetro de seguridad.

El Responsable de Seguridad Informática debería llevar un registro actualizado de los sitios protegidos, indicando:

- a) Identificación del Edificio y Área.



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

b) Principales elementos a proteger

4.2. Controles de Acceso Físico

Se debería considerar la implementación de controles de acceso físico contemplando las siguientes acciones:

- a) Supervisar o inspeccionar a los visitantes a áreas protegidas y registrar la fecha y horario de su ingreso y egreso. Sólo se debería permitir el acceso mediando propósitos específicos y autorizados e instruyéndose al visitante, en el momento de ingreso, sobre los requerimientos de seguridad del área y los procedimientos de emergencia.
- b) Controlar y limitar el acceso a la información clasificada y a las instalaciones de procesamiento de información, exclusivamente a las personas autorizadas. Se deberían utilizar controles de autenticación para autorizar y validar todos los accesos. Se debería mantener un registro protegido para permitir auditar todos los accesos.
- c) Implementar el uso de una identificación unívoca visible para todo el personal del área protegida e instruirlo acerca de cuestionar la presencia de desconocidos no escoltados por personal autorizado y a cualquier persona que no exhiba una identificación visible.
- d) Revisar y actualizar periódicamente los derechos de acceso a las áreas protegidas, los que deberían ser documentados y firmados por el Responsable de la Unidad Organizativa de la que dependa.
- e) Revisar los registros de acceso a las áreas protegidas. Esta tarea debería realizarla la Unidad de Auditoría Interna o en su defecto quien sea propuesto por el Comité de Seguridad de la Información.

4.3. Protección de Oficinas, Recintos e Instalaciones

Se deberían definir las áreas protegidas, teniendo en cuenta la posibilidad de daño producido por incendio, inundación, explosión, agitación civil, y otras formas de desastres naturales o provocados por el hombre.

Se debería establecer algunas o todas de las siguientes medidas de protección para áreas protegidas:

- a) Ubicar las instalaciones críticas en lugares a los cuales no pueda acceder personal no autorizado.
- b) Establecer que los edificios o sitios donde se realicen actividades de procesamiento de información serán discretos y ofrecerán un señalamiento mínimo de su propósito, sin signos obvios, exteriores o interiores.
- c) Ubicar las funciones y el equipamiento de soporte, por ejemplo: impresoras, fotocopadoras, máquinas de fax, adecuadamente dentro del área protegida para evitar solicitudes de acceso, el cual podría comprometer la información.



Comité de Seguridad de la Información

Coordinación General

- d) Establecer que las puertas y ventanas permanecerán cerradas cuando no haya vigilancia. Se agregará protección externa a las ventanas, en particular las que se encuentran en planta baja o presenten riesgos especiales.
- e) Implementar mecanismos de control para la detección de intrusos, que deberían ser instalados según estándares profesionales y probados periódicamente.
- f) Separar las instalaciones de procesamiento de información administradas por el Organismo de aquellas administradas por terceros.
- g) Restringir el acceso público a las guías telefónicas y listados de teléfonos internos que identifiquen las ubicaciones de las instalaciones de procesamiento de información sensible.
- h) Almacenar los materiales peligrosos o combustibles en los siguientes lugares seguros a una distancia prudencial de las áreas protegidas de la Universidad. Los suministros, como los útiles de escritorio, no serán trasladados al área protegida hasta que sean requeridos.
- i) Almacenar los equipos redundantes y la información de resguardo (back up) en un sitio seguro y distante del lugar de procesamiento, para evitar daños ocasionados ante eventuales contingencias en el sitio principal.

4.4. Desarrollo de Tareas en Áreas protegidas

Se debería considerar la implementación de las siguientes acciones:

- a) Dar a conocer al personal la existencia del área protegida, o de las actividades que allí se llevan a cabo, sólo si es necesario para el desarrollo de sus funciones.
- b) Evitar la ejecución de trabajos por parte de terceros sin supervisión.
- c) Bloquear físicamente e inspeccionar periódicamente las áreas protegidas desocupadas.
- d) Limitar el acceso al personal del servicio de soporte externo a las áreas protegidas o a las instalaciones de procesamiento de información sensible. Este acceso, como el de cualquier otra persona ajena que requiera acceder al área protegida, será otorgado solamente cuando sea necesario y se encuentre autorizado y monitoreado. Se mantendrá un registro de todos los accesos de personas ajenas.
- e) Pueden requerirse barreras y perímetros adicionales para controlar el acceso físico entre áreas con diferentes requerimientos de seguridad, y que están ubicadas dentro del mismo perímetro de seguridad.
- f) Impedir el ingreso de equipos de computación móvil, fotográficos, de vídeo, audio o cualquier otro tipo de equipamiento que registre información, a menos que hayan sido formalmente autorizadas por el Responsable de dicho área o el Responsable del Área Informática y el Responsable de Seguridad Informática.
- g) Prohibir comer, beber y fumar dentro de las instalaciones de procesamiento de la información.



Comité de Seguridad de la Información
Coordinación General

4.5. Aislamiento de las Áreas de Recepción y Distribución

Se deberían controlar las áreas de Recepción y Distribución, las cuales deberían estar aisladas de las instalaciones de procesamiento de información, a fin de impedir accesos no autorizados. Para ello se deberían establecer controles físicos que complementarían las siguientes acciones:

- a) Limitar el acceso a las áreas de depósito, desde el exterior de la sede de la Universidad, sólo al personal previamente identificado y autorizado.
- b) Diseñar el área de depósito de manera tal que los suministros puedan ser descargados sin que el personal que realiza la entrega acceda a otros sectores del edificio.
- c) Proteger todas las puertas exteriores del depósito cuando se abre la puerta interna.
- d) Inspeccionar el material entrante para descartar peligros potenciales antes de ser trasladado desde el área de depósito hasta el lugar de uso.
- e) Registrar el material entrante al ingresar al sitio pertinente.

4.6. Ubicación y Protección del Equipamiento y Copias de Seguridad

El equipamiento debería ser ubicado y protegido de tal manera que se reduzcan los riesgos ocasionados por amenazas y peligros ambientales, y las oportunidades de acceso no autorizado, teniendo en cuenta los siguientes puntos:

- a) Ubicar el equipamiento en un sitio donde se minimice el acceso innecesario y provea un control de acceso adecuado.
- b) Ubicar las instalaciones de procesamiento y almacenamiento de información que manejan datos clasificados, en un sitio que permita la supervisión durante su uso.
- c) Aislar los elementos que requieren protección especial para reducir el nivel general de protección requerida.
- d) Adoptar controles adecuados para minimizar el riesgo de amenazas potenciales, por:

Amenazas Potenciales Controles

Robo o hurto

Incendio

Explosivos

Humo

Inundaciones o filtraciones de agua (o falta de suministro)

Polvo



Comité de Seguridad de la Información

Coordinación General

Vibraciones

Efectos químicos

Interferencia en el suministro de energía eléctrica (cortes de suministro, variación de tensión)

Radiación electromagnética

Derrumbes

e) Revisar regularmente las condiciones ambientales para verificar que las mismas no afecten de manera adversa el funcionamiento de las instalaciones de procesamiento de la información. Esta revisión debería realizarse con una periodicidad no mayor a seis meses.

f) Considerar asimismo el impacto de las amenazas citadas en el punto d) que tengan lugar en zonas próximas a la sede de la Universidad.

4.7. Suministros de Energía

Para asegurar la continuidad del suministro de energía, se debería contemplar las siguientes medidas de control:

a) Disponer de múltiples enchufes o líneas de suministro para evitar un único punto de falla en el suministro de energía.

b) Contar con un suministro de energía ininterrumpible (UPS) para asegurar el apagado regulado y sistemático o la ejecución continua del equipamiento que sustenta las operaciones críticas de la Universidad. La determinación de dichas operaciones críticas, debería ser el resultado del análisis de impacto realizado por el Responsable de Seguridad Informática conjuntamente con los Propietarios de la Información con incumbencia. Los planes de contingencia deberían contemplar las acciones que han de emprenderse ante una falla de la UPS. Los equipos de UPS deberían ser inspeccionados y probados periódicamente para asegurar que funcionan correctamente y que tuviesen la autonomía requerida.

c) Montar un generador de respaldo para los casos en que el procesamiento deba continuar ante una falla prolongada en el suministro de energía. Debería realizarse un análisis de impacto de las posibles consecuencias ante una interrupción prolongada del procesamiento, con el objeto de definir qué componentes será necesario abastecer de energía alternativa. Dicho análisis debería ser realizado por el Responsable de Seguridad Informática, conjuntamente con los Propietarios de la Información. Se debería disponer de un adecuado suministro de combustible para garantizar que el generador pueda funcionar por un período prolongado. Cuando el encendido de los generadores no sea automático, se debería asegurar que el tiempo de funcionamiento de la UPS permitiese el encendido manual de los mismos. Los generadores deberían ser inspeccionados y probados periódicamente para asegurar que funcionen según lo previsto.

Asimismo, se debería procurar que los interruptores de emergencia se ubiquen cerca de las



Comité de Seguridad de la Información

Coordinación General

salidas de emergencia de las salas donde se encuentra el equipamiento, a fin de facilitar un corte rápido de la energía en caso de producirse una situación crítica. Se debería proveer iluminación de emergencia, para el caso de producirse una falla en el suministro principal de energía. Se debería implementar protección contra descargas eléctricas en todos los edificios y líneas de comunicaciones externas de acuerdo a las normativas vigentes.

4.8. Seguridad del Cableado

El cableado de energía eléctrica y de comunicaciones que transporta datos o brinda apoyo a los servicios de información debería ser protegido contra interceptación o daño mediante las siguientes acciones:

- a) Cumplir con los requisitos técnicos vigentes de la República Argentina.
- b) Utilizar pisoducto o cableado embutido en la pared, siempre que sea posible, cuando corresponda a las instalaciones de procesamiento de información. En su defecto, deberían estar sujetas a protección alternativa.
- c) Proteger el cableado de red contra interceptación no autorizada o daño mediante controles, como por ejemplo: el uso de conductos o evitando trayectos que atraviesen áreas públicas.
- d) Separar los cables de energía de los cables de comunicaciones para evitar interferencias.
- e) Proteger el tendido del cableado troncal (backbone) mediante la utilización de ductos blindados. Para los sistemas sensibles o críticos, se deberían implementar los siguientes controles adicionales:
 - a) Instalar conductos blindados y recintos o cajas con cerradura en los puntos terminales y de inspección.
 - b) Utilizar rutas o medios de transmisión alternativos.

4.9. Mantenimiento de Equipos

Se debería realizar el mantenimiento del equipamiento para asegurar su disponibilidad e integridad permanentes, teniendo en cuenta a tal efecto:

- a) la realización de tareas de mantenimiento preventivo al equipamiento, de acuerdo con los intervalos de servicio y especificaciones recomendados por el proveedor y con la autorización formal del Responsables del Área Informática.
- b) el establecimiento de la práctica de que sólo el personal de mantenimiento autorizado puede brindar mantenimiento y llevar a cabo reparaciones en el equipamiento.
- c) la registración de todas las fallas -supuestas y/o reales- y de todo el mantenimiento preventivo y correctivo realizado.
- d) la registración del retiro de equipamiento para su mantenimiento de la sede de la Universidad.
- e) la eliminación de toda información confidencial que contenga cualquier equipamiento que sea necesario retirar, realizándose previamente las respectivas copias de resguardo.



Comité de Seguridad de la Información
Coordinación General

4.10. Seguridad de los Equipos fuera de las Instalaciones

El uso de equipamiento destinado al procesamiento de información, fuera del ámbito de la Universidad debería ser autorizado por el responsable patrimonial. En el caso de que en el mismo se almacene información clasificada, deberá ser aprobado además por el Propietario de la misma. La seguridad provista debería ser equivalente a la suministrada dentro del ámbito de la Universidad para un propósito similar.

4.11. Desafectación o Reutilización Segura de los Equipos

La información puede verse comprometida por una desafectación o una reutilización descuidada del equipamiento. Los medios de almacenamiento conteniendo material sensible, por ejemplo discos rígidos no removibles, deberían ser físicamente destruidos o sobrescritos en forma segura, en lugar de utilizar las funciones de borrado estándar, según corresponda.

4.12. Políticas de Escritorios y Pantallas Limpias

Se debería aplicar los siguientes lineamientos:

- a) Almacenar bajo llave, cuando corresponda, los documentos en papel y los medios informáticos, en gabinetes y/u otro tipo de mobiliario seguro cuando no están siendo utilizados, especialmente fuera del horario de trabajo.
- b) Guardar bajo llave la información sensible o crítica de la Universidad (preferentemente en una caja fuerte o gabinete a prueba de incendios) cuando no está en uso, especialmente cuando no hay personal en la oficina.
- c) Desconectar de la red / sistema / servicio las computadoras personales, terminales e impresoras asignadas a funciones críticas, cuando están desatendidas. Las mismas deben ser protegidas mediante cerraduras de seguridad, contraseñas u otros controles cuando no están en uso (como por ejemplo la utilización de protectores de pantalla con contraseña). Los responsables de cada área deberían mantener un registro de las contraseñas o copia de las llaves de seguridad utilizadas en el sector a su cargo. Tales elementos deberían encontrarse protegidos en sobre cerrado o caja de seguridad para impedir accesos no autorizados, debiendo dejarse constancia de todo acceso a las mismas, y de los motivos que llevaron a tal acción.
- d) Proteger los puntos de recepción y envío de correo postal y las máquinas de fax no atendidas.
- e) Bloquear las fotocopadoras (o protegerlas de alguna manera del uso no autorizado) fuera del horario normal de trabajo.
- f) Retirar inmediatamente la información sensible o confidencial, una vez impresa.



Comité de Seguridad de la Información

Coordinación General

4.13. Retiro de los Bienes

El equipamiento, la información y el software no debería ser retirados de la sede de la Universidad sin autorización formal. Periódicamente, se deberían llevar a cabo comprobaciones puntuales para detectar el retiro no autorizado de activos de la Universidad. El personal debería ser puesto en conocimiento de la posibilidad de realización de dichas comprobaciones.

GESTION DE COMUNICACIONES Y OPERACIONES

Se deberían determinar los requerimientos para resguardar la información por la cual es responsable.

5.1. Procedimientos y Responsabilidades Operativas

5.1.1. Documentación de los Procedimientos Operativos. Se deberían establecer procedimientos con instrucciones para la ejecución detallada de cada tarea, incluyendo:

- a) Procesamiento y manejo de la información.
- b) Requerimientos de programación de procesos, interdependencias con otros sistemas, tiempos de inicio de las primeras tareas y tiempos de terminación de las últimas tareas.
- c) Instrucciones para el manejo de errores u otras condiciones excepcionales que puedan surgir durante la ejecución de tareas.
- d) Restricciones en el uso de utilitarios del sistema.

Se debería preparar adicionalmente, documentación sobre procedimientos referidos a las siguientes actividades:

- a) Instalación y mantenimiento de equipamiento para el procesamiento de información y comunicaciones.
- b) Instalación y mantenimiento de las plataformas de procesamiento.
- c) Monitoreo del procesamiento y las comunicaciones.
- d) Inicio y finalización de la ejecución de los sistemas.
- e) Programación y ejecución de procesos.
- f) Gestión de servicios.
- g) Resguardo de información.
- h) Gestión de incidentes de seguridad en el ambiente de procesamiento y comunicaciones.
- i) Reemplazo o cambio de componentes del ambiente de procesamiento y comunicaciones.



Comité de Seguridad de la Información
Coordinación General

j) Uso del correo electrónico.

5.1.2. Control de Cambios en las Operaciones. Se deberían establecer procedimientos de control de cambios contemplando los siguientes puntos:

- a) Identificación y registro de cambios significativos.
- b) Evaluación del posible impacto de dichos cambios.
- c) Aprobación formal de los cambios propuestos.
- d) Planificación del proceso de cambio.
- e) Prueba del nuevo escenario.
- f) Comunicación de detalles de cambios a todas las personas pertinentes.
- g) Identificación de las responsabilidades por la cancelación de los cambios fallidos y la recuperación respecto de los mismos.

Se debería tener un registro de auditoría, que contenga toda la información relevante de cada cambio implementado

5.1.3. Procedimientos de Manejos de Incidentes. Se debería considerar los siguientes ítems:

- a) Contemplar y definir todos los tipos probables de incidentes relativos a seguridad, incluyendo:
 - 1. Fallas operativas
 - 2. Código malicioso
 - 3. Intrusiones
 - 4. Fraude informático
 - 5. Error humano
 - 6. Catástrofes naturales
- b) Comunicar los incidentes a través de canales jerárquicos apropiados tan pronto como sea posible.
- c) Contemplar los siguientes puntos en los procedimientos para los planes de contingencia normales (diseñados para recuperar sistemas y servicios tan pronto como sea posible):
 - 1. Definición de las primeras medidas a implementar
 - 2. Análisis e identificación de la causa del incidente.
 - 3. Planificación e implementación de soluciones para evitar la repetición del mismo, si fuera necesario.
 - 4. Comunicación con las personas afectadas o involucradas con la recuperación,



Comité de Seguridad de la Información

Coordinación General

del incidente.

5. Notificación de la acción a la autoridad y/u Organismos pertinentes.

d) Registrar pistas de auditoría y evidencia similar para:

1. Análisis de problemas internos.
2. Uso como evidencia en relación con una probable violación contractual o infracción normativa, o en marco de un proceso judicial.
3. Negociación de compensaciones por parte de los proveedores de software y de servicios.

e) Implementación de controles detallados y formalizados de las acciones de recuperación respecto de las violaciones de la seguridad y de corrección de fallas del sistema, garantizando:

1. Acceso a los sistemas y datos existentes sólo al personal claramente identificado y autorizado.
2. Documentación de todas las acciones de emergencia emprendidas en forma detallada.
3. Comunicación de las acciones de emergencia al titular de la Unidad Organizativa y revisión de su cumplimiento.
4. Constatación de la integridad de los controles y sistemas del Organismo en un plazo mínimo.

En los casos en los que se considere necesario, se debería solicitar la participación del Responsable del Área Legal del Organismo en el tratamiento de incidentes de seguridad ocurridos.

5.1.4. Separación de funciones. Se debería contemplar la separación de la gestión o ejecución de tareas o áreas de responsabilidad, en la medida de que la misma reduzca el riesgo de modificaciones no autorizadas o mal uso de la información.

- a) Separar actividades que requieren connivencia para defraudar, por ejemplo efectuar una orden de compra y verificar que la mercadería fue recibida.
- b) Diseñar controles, si existe peligro de connivencia de manera tal que dos o más personas estén involucradas, reduciendo la posibilidad de conspiración.

5.1.5. Separación entre Instalaciones de Desarrollo e Instalaciones Operativas. Para ello, se debería tener en cuenta los siguientes controles:

- a) Ejecutar el software de desarrollo y de operaciones, en diferentes ambientes de operaciones, equipos, o directorios.
- b) Separar las actividades de desarrollo y prueba, en entornos diferentes.
- c) Impedir el acceso a los compiladores, editores y otros utilitarios del sistema en el am-



Comité de Seguridad de la Información

Coordinación General

biente operativo, cuando no sean indispensables para el funcionamiento del mismo.

d) Utilizar sistemas de autenticación y autorización independientes para los diferentes ambientes, así como perfiles de acceso a los sistemas. Prohibir a los usuarios compartir contraseñas en estos sistemas. Las interfaces de los sistemas identificarán claramente a qué instancia se está realizando la conexión.

e) Definir propietarios de la información para cada un de los ambientes de procesamiento existentes.

f) El personal de desarrollo no debería tener acceso al ambiente operativo. De ser extrema dicha necesidad, se debería establecer un procedimiento de emergencia para la autorización, documentación y registro de dichos accesos.

5.1.6. Gestión de Instalaciones Externas. En el caso de tercerizar la administración de las instalaciones de procesamiento, se debería acordar controles con el proveedor del servicio que se deberían incluir en el contrato de tercerización, contemplando las siguientes cuestiones específicas:

a) Identificar las aplicaciones sensibles o críticas que convenga retener en la Universidad.

b) Obtener la aprobación de los propietarios de aplicaciones específicas.

c) Identificar las implicancias para la continuidad de los planes de las actividades de la Universidad.

d) Especificar las normas de seguridad y el proceso de medición del cumplimiento.

e) Asignar funciones específicas y procedimientos para monitorear todas las actividades de seguridad.

f) Definir las funciones y procedimientos de comunicación y manejo de incidentes relativos a la seguridad.

Dichas consideraciones deberían ser acordadas entre el Responsable de Seguridad Informática, el Responsable del Área de Informática y el Responsable del Área Legal de la Universidad.

5.2. Planificación y aprobación del sistema

5.2.1. Planificación de la Capacidad. Se debería efectuar el monitoreo de las necesidades de capacidad de los sistemas en operación y proyectar las futuras demandas, a fin de garantizar un procesamiento y almacenamiento adecuados. Para ello, se debería tomar en cuenta -además- los nuevos requerimientos de los sistemas, así como las tendencias actuales y proyectadas en el procesamiento de la información de la Universidad para el período estipulado de vida útil de cada componente. Asimismo, se deberían informar a las autoridades competentes las necesidades detectadas, para que las mismas pudieran identificar y evitar potenciales cuellos de botella, que podrían plantear una amenaza a la seguridad o a la continuidad del procesamiento, y pudieran planificar una adecuada acción correctiva en consecuencia.

5.2.2. Aprobación del Sistema. Se debería sugerir criterios de aprobación para nuevos sistemas



Comité de Seguridad de la Información

Coordinación General

de información, actualizaciones y nuevas versiones, solicitando la realización de las pruebas necesarias antes de su aprobación definitiva. Se deberían considerar los siguientes puntos:

- a) Verificar el impacto en el desempeño y los requerimientos de capacidad de las computadoras.
- b) Garantizar la recuperación ante errores.
- c) Preparar y poner a prueba los procedimientos operativos de rutina según normas definidas.
- d) Garantizar la implementación de un conjunto acordado de controles de seguridad.
- e) Confeccionar disposiciones relativas a la continuidad de las actividades de la Universidad.
- f) Asegurar que la instalación del nuevo sistema no afectará negativamente los sistemas existentes, especialmente en los períodos pico de procesamiento.
- g) Considerar el efecto que tiene el nuevo sistema en la seguridad global de la Universidad.
- h) Disponer la realización de entrenamiento en la operación y/o uso de nuevos sistemas.

5.3. Protección Contra Software Malicioso

5.3.1. Controles Contra Software Malicioso. Se deberían definir controles de detección y prevención para la protección contra software malicioso y la implementación de dichos controles. También se deberían desarrollar procedimientos adecuados de concientización de usuarios en materia de seguridad, controles de acceso al sistema y administración de cambios. Estos controles deberían considerar las siguientes acciones:

- a) Prohibir el uso de software no autorizado por la Universidad.
- b) Redactar procedimientos para evitar los riesgos relacionados con la obtención de archivos y software desde o a través de redes externas, o por cualquier otro medio, señalando las medidas de protección a tomar.
- c) Instalar y actualizar periódicamente software de detección y reparación de virus, examinando computadoras y medios informáticos, como medida precautoria y rutinaria.
- d) Mantener los sistemas al día con las últimas actualizaciones de seguridad disponibles (probar dichas actualizaciones en un entorno de prueba previamente si es que constituyen cambios críticos a los sistemas).
- e) Revisar periódicamente el contenido de software y datos de los equipos de procesamiento que sustentan procesos críticos de la Universidad, investigando formalmente la presencia de archivos no aprobados o modificaciones no autorizadas.
- f) Verificar antes de su uso, la presencia de virus en archivos de medios electrónicos de



Comité de Seguridad de la Información

Coordinación General

origen incierto, o en archivos recibidos a través de redes no confiables.

g) Redactar procedimientos para verificar toda la información relativa a software malicioso, garantizando que los boletines de alerta sean exactos e informativos.

h) Concientizar al personal acerca del problema de los falsos virus (hoax) y de cómo proceder frente a los mismos.

5.4. Mantenimiento

5.4.1. Resguardo de la Información. Se deberían determinar los requerimientos para resguardar cada software o dato en función de su criticidad. En base a ello, se debería definir y documentar un esquema de resguardo de la información. Se deberían determinar procedimientos para el resguardo de la información, que deberían considerar los siguientes puntos:

- a) Definir un esquema de rótulo de las copias de resguardo, que permita contar con toda la información necesaria para identificar cada una de ellas y administrarlas debidamente.
- b) Establecer un esquema de reemplazo de los medios de almacenamiento de las copias de resguardo, una vez concluida la posibilidad de ser reutilizados, de acuerdo a lo indicado por el proveedor, y asegurando la destrucción de los medios desechados
- c) Almacenar en una ubicación remota copias recientes de información de resguardo junto con registros exactos y completos de las mismas y los procedimientos documentados de restauración, a una distancia suficiente como para evitar daños provenientes de un desastre en el sitio principal. Se deberán retener al menos tres generaciones o ciclos de información de resguardo para la información y el software esenciales para la Universidad. Para la definición de información mínima a ser resguardada en el sitio remoto, se debería tener en cuenta el nivel de clasificación otorgado a la misma, en términos de disponibilidad (Clasificación de la información) y requisitos legales a los que se encuentre sujeta.
- d) Asignar a la información de resguardo un nivel de protección física y ambiental según las normas aplicadas en el sitio principal. Extender los mismos controles aplicados a los dispositivos en el sitio principal al sitio de resguardo.
- e) Probar periódicamente los medios de resguardo.
- f) Verificar y probar periódicamente los procedimientos de restauración garantizando su eficacia y cumplimiento dentro del tiempo asignado a la recuperación en los procedimientos operativos.

5.4.2. Registro de Actividades del Personal Operativo. Se debería asegurar el registro de las actividades realizadas en los sistemas, incluyendo según corresponda

- a) Tiempos de inicio y cierre del sistema.
- b) Errores del sistema y medidas correctivas tomadas.



Comité de Seguridad de la Información

Coordinación General

- c) Intentos de acceso a sistemas, recursos o información crítica o acciones restringidas
- d) Ejecución de operaciones críticas
- e) Cambios a información crítica

La Unidad de Auditoría Interna o en su defecto quien sea propuesto por el Comité de Seguridad de la Información debería contrastar los registros de actividades del personal operativo con relación a los procedimientos operativos.

5.4.3. Registro de Fallas. Se debería registrar las fallas comunicadas, que observara reglas claras para el manejo de las mismas, con inclusión de:

- a) Revisión de registros de fallas para garantizar que las mismas fueron resueltas satisfactoriamente.
- b) Revisión de medidas correctivas para garantizar que los controles no fueron comprometidos, y que las medidas tomadas fueron autorizadas.
- c) Documentación de la falla con el objeto de prevenir su repetición o facilitar su resolución en caso de reincidencia.

5.5. Administración de la Red

5.5.1. Controles de Redes. Se debería establecer controles que consideren la ejecución de las siguientes acciones:

- a) Establecer los procedimientos para la administración del equipamiento remoto, incluyendo los equipos en las áreas usuarias, la que debería ser llevada a cabo por el responsable establecido en el punto “Asignación de Responsabilidades en Materia de Seguridad de la Información”.
- b) Establecer controles especiales para salvaguardar la confidencialidad e integridad del procesamiento de los datos que pasan a través de redes públicas, y para proteger los sistemas conectados. Implementar controles especiales para mantener la disponibilidad de los servicios de red y computadoras conectadas.
- c) Garantizar mediante actividades de supervisión, que los controles se aplican uniformemente en toda la infraestructura de procesamiento de información.

El Responsable del Área Informática debería implementar dichos controles

5.6. Administración y Seguridad de los medios de Almacenamiento

5.6.1. Administración de Medios de Almacenamientos Removibles. Los procedimientos se deberían realizar de acuerdo al capítulo 6 – “Control de Accesos”. Se deberían considerar las siguientes acciones para la implementación de los procedimientos:

- a) Eliminar de forma segura los contenidos, si ya no son requeridos, de cualquier medio reutilizable que ha de ser retirado o reutilizado por el Organismo



Comité de Seguridad de la Información

Coordinación General

b) Requerir autorización para retirar cualquier medio del Organismo y realizar un control de todos los retiros a fin de mantener un registro de auditoría.

c) Almacenar todos los medios en un ambiente seguro y protegido, de acuerdo con las especificaciones de los fabricantes o proveedores.

Se deberían documentar todos los procedimientos y niveles de autorización, en concordancia con el capítulo 2. Clasificación y Control de Activos

5.6.2. Eliminación de Medios de Información. Se deberían establecer procedimientos, que consideren a los siguientes elementos para su eliminación segura:

- a) Documentos en papel.
- b) Voces u otras grabaciones.
- c) Papel carbónico.
- d) Informes de salida.
- e) Cintas de impresora de un solo uso.
- f) Cintas magnéticas.
- g) Discos o casetes removibles.
- h) Medios de almacenamiento óptico (todos los formatos incluyendo todos los medios de distribución de software del fabricante o proveedor).
- i) Listados de programas.
- j) Datos de prueba.
- k) Documentación del sistema.

5.6.3. Procedimientos de Manejo de la Información. Se deberían establecer procedimientos que contemplen las siguientes acciones:

- a) Incluir en la protección a documentos, sistemas informáticos, redes, computación móvil, comunicaciones móviles, correo, correo de voz, comunicaciones de voz en general, multimedia, servicios e instalaciones postales, uso de máquinas de fax y cualquier otro ítem potencialmente sensible.
- b) Restringir el acceso solo al personal debidamente autorizado.
- c) Mantener un registro formal de los receptores autorizados de datos.
- d) Garantizar que los datos de entrada son completos, que el procesamiento se lleva a cabo correctamente y que se valida las salidas.
- e) Proteger los datos en espera ("colas").
- f) Conservar los medios de almacenamiento en un ambiente que concuerde con las especificaciones de los fabricantes o proveedores.



Comité de Seguridad de la Información

Coordinación General

5.6.4. Seguridad de la Documentación del Sistema. La documentación del sistema puede contener información sensible, por lo que se debería considerar establecer los recaudos para su protección, de almacenar la documentación del sistema en forma segura y restringir el acceso a la documentación del sistema al personal estrictamente necesario.

5.7. Intercambio de Información y Software

5.7.1. Acuerdos de Intercambio de Información y Software. Se deberían tener en cuenta los siguientes aspectos:

- a) Responsabilidades por el control y la notificación de transmisiones, envíos y recepciones.
- b) Procedimientos de notificación de emisión, transmisión, envío y recepción.
- c) Normas técnicas para el empaquetado y la transmisión.
- d) Pautas para la identificación del prestador del servicio de correo.
- e) Responsabilidades y obligaciones en caso de pérdida de datos.
- f) Uso de un sistema convenido para el rotulado de información clasificada, garantizando que el significado de los rótulos sea inmediatamente comprendido y que la información sea adecuadamente protegida.
- g) Términos y condiciones de la licencia bajo la cual se suministra el software.
- h) Información sobre la propiedad de la información suministrada y las condiciones de su uso.
- i) Normas técnicas para la grabación y lectura de la información y del software.
- j) Controles especiales que puedan requerirse para proteger ítems sensibles, (claves criptográficas, etc.).

5.7.2. Seguridad de los Medios en Tránsito. Se deberían establecer procedimientos de transporte de medios informáticos entre diferentes puntos (envíos postales y mensajería) contemplando la utilización de medios de transporte o servicios de mensajería confiables como:

- 1. Uso de recipientes cerrados.
- 2. Entrega en mano.
- 3. Embalaje a prueba de apertura no autorizada (que revele cualquier intento de acceso).
- 4. En casos excepcionales, división de la mercadería a enviar en más de una entrega y envío por diferentes rutas.

5.7.3. Seguridad del Gobierno Electrónico. Se debería verificar que los procedimientos de aprobación de Software del punto "Aprobación del Sistema" incluyan, para las aplicaciones de Gobierno Electrónico, los siguientes aspectos:



Comité de Seguridad de la Información

Coordinación General

- a) Autenticación: Nivel de confianza recíproca suficiente sobre la identidad del usuario y la Universidad.
- b) Autorización: Niveles de Autorización adecuados para establecer disposiciones, emitir o firmar documentos clave, etc.. Forma de comunicarlo al otro participante de la transacción electrónica.
- c) Procesos de oferta y contratación pública: Requerimientos confidencialidad, integridad y prueba de envío y recepción de documentos clave y de no repudio de contratos.
- d) Trámites en línea: Confidencialidad, integridad y no repudio de los datos suministrados con respecto a trámites y presentaciones ante el Estado y confirmación de recepción.
- e) Verificación: Grado de verificación apropiado para constatar la información suministrada por los usuarios.
- f) Cierre de la transacción: Forma de interacción más adecuada para evitar fraudes.
- g) Protección a la duplicación: Asegurar que una transacción sólo se realiza una vez, a menos que se especifique lo contrario.
- h) No repudio: Manera de evitar que una entidad que haya enviado o recibido información alegue que no la envió o recibió.
- i) Responsabilidad: Asignación de responsabilidades ante el riesgo de eventuales presentaciones, tramitaciones o transacciones fraudulentas.

Las consideraciones mencionadas se deberían implementar mediante la aplicación de las técnicas criptográficas enumeradas en el punto "Política de Utilización de Controles Criptográficos." y tomando en cuenta el cumplimiento de los requisitos legales emanados de toda la normativa vigente. Se darán a conocer a los usuarios, los términos y condiciones aplicables.

5.7.4. Seguridad del Correo Electrónico

5.7.4.1. Riesgos de Seguridad. Se debería considerar la implementación de controles, contemplando:

- a) La vulnerabilidad de los mensajes al acceso o modificación no autorizados o a la negación de servicio.
- b) La posible interceptación y el consecuente acceso a los mensajes en los medios de transferencia que intervienen en la distribución de los mismos.
- c) Las posibles vulnerabilidades a errores, por ejemplo, consignación incorrecta de la dirección o dirección errónea, y la confiabilidad y disponibilidad general del servicio.
- d) La posible recepción de código malicioso en un mensaje de correo, el cual afecte la seguridad de la terminal receptora o de la red a la que se encuentra conectada.
- e) El impacto de un cambio en el medio de comunicación en los procesos del Orga-



Comité de Seguridad de la Información

Coordinación General

nismo.

f) Las consideraciones legales, como la necesidad potencial de contar con prueba de origen, envío, entrega y aceptación.

g) Las implicancias de la publicación externa de listados de personal, accesibles al público.

h) El acceso de usuarios remotos a las cuentas de correo electrónico.

i) El uso inadecuado por parte del personal.

5.7.4.2. Política de Correo Electrónico. Se debería definir normas y procedimientos sobre:

a) Protección contra ataques al correo electrónico, por ejemplo virus, interceptación, etc.

b) Protección de archivos adjuntos de correo electrónico.

c) Uso de técnicas criptográficas para proteger la confidencialidad e integridad de los mensajes electrónicos (Ver 7.3. Controles Criptográficos).

d) Retención de mensajes que, si se almacenaran, pudieran ser usados en caso de litigio.

e) Controles adicionales para examinar mensajes electrónicos que no pueden ser autenticados.

f) Aspectos operativos para garantizar el correcto funcionamiento del servicio (ej.: tamaño máximo de información transmitida y recibida, cantidad de destinatarios, tamaño máximo del buzón del usuario, etc.).

g) Definición de los alcances del uso del correo electrónico por parte del Personal de la Universidad.

La Universidad debería informar claramente a sus empleados: a) cuál es el uso que la Universidad espera que los empleados hagan del correo electrónico provisto por la Universidad; y b) bajo qué condiciones los mensajes pueden ser objeto de control y monitoreo.

5.7.5. Seguridad de los Sistemas Electrónicos de Oficina. Se debería controlar los mecanismos de distribución y difusión tales como documentos, computadoras, computación móvil, comunicaciones móviles, correo, correo de voz, etc. Al interconectar dichos medios, se considerarán las implicancias en lo que respecta a la seguridad y a las actividades propias de la Universidad, incluyendo:

a) Vulnerabilidades de la información en los sistemas de oficina, por ejemplo la grabación de llamadas telefónicas o teleconferencias, la confidencialidad de las llamadas, el almacenamiento de faxes, la apertura o distribución del correo.



Comité de Seguridad de la Información

Coordinación General

- b) Procedimientos y controles apropiados para administrar la distribución de información, por ejemplo el uso de boletines electrónicos institucionales.
- c) Exclusión de categorías de información sensible del Organismo, si el sistema no brinda un adecuado nivel de protección.
- d) Limitación del acceso a la información de las actividades que desarrollan determinadas personas, por ejemplo aquellas que trabaja en proyectos sensibles.
- e) La aptitud del sistema para dar soporte a las aplicaciones del Organismo, como la comunicación de órdenes o autorizaciones.
- f) Categorías de personal y contratistas o terceros a los que se permite el uso del sistema y las ubicaciones desde las cuales se puede acceder al mismo.
- g) Restricción de acceso a determinadas instalaciones a específicas categorías de usuarios.
- h) Identificación de la posición o categoría de los usuarios, por ejemplo empleados del Organismo o contratistas, en directorios accesibles por otros usuarios.
- i) Retención y resguardo de la información almacenada en el sistema.
- j) Requerimientos y disposiciones relativos a sistemas de soporte de reposición de información previa.

5.7.6. Sistemas de Acceso Público. Se debería prever que todos los sistemas de acceso público consideren lo siguiente:

- a) La información se obtenga, procese y proporcione de acuerdo a la normativa vigente, en especial la Ley de Protección de Datos Personales.
- b) La información que se ingresa al sistema de publicación, o aquella que procesa el mismo, sea procesada en forma completa, exacta y oportuna.
- c) La información sensible sea protegida durante el proceso de recolección y su almacenamiento.
- d) El acceso al sistema de publicación no permita el acceso accidental a las redes a las cuales se conecta el mismo.
- e) Se registre al responsable de la publicación de información en sistemas de acceso público.
- f) La información se publique teniendo en cuenta las normas establecidas al respecto.
- g) Se garantice la validez y vigencia de la información publicada.

5.7.7. Otras Formas de Intercambio de Información. Se debería implementar normas, procedimientos y controles para proteger el intercambio de información a través de medios de comunicaciones de voz, fax y vídeo, contemplando las siguientes acciones:



Comité de Seguridad de la Información

Coordinación General

a) Concientizar al personal sobre la toma de debidas precauciones, por ejemplo no revelar información sensible como para evitar ser escuchado o interceptado, al hacer una llamada telefónica, por:

1. Personas cercanas, en especial al utilizar teléfonos móviles.

2. Terceros que tengan acceso a la comunicación mediante la Intervención de la línea telefónica, y otras formas de escucha subrepticias, a través del acceso físico al aparato o a la línea telefónica, o mediante equipos de barrido de frecuencias al utilizar teléfonos móviles análogos.

3. Terceros en el lado receptor.

b) Recordar al personal que no sostengan conversaciones confidenciales en lugares públicos u oficinas abiertas y lugares de reunión con paredes delgadas.

c) No dejar mensajes en contestadores automáticos puesto que éstos pueden ser escuchados por personas no autorizadas, almacenados en sistemas públicos o almacenados incorrectamente como resultado de un error de discado.

d) Recordar al personal los problemas ocasionados por el uso de máquinas de fax, en particular:

1. El acceso no autorizado a sistemas incorporados de almacenamiento de mensajes con el objeto de recuperarlos.

2. La programación deliberada o accidental de equipos para enviar mensajes a determinados números.

3. El envío de documentos y mensajes a un número equivocado por errores de discado o por utilizar el número almacenado equivocado.

CONTROL DE ACCESOS

6.1. Requerimientos para el Control de Acceso

6.1.1. Política de Control de Accesos. En la aplicación de controles de acceso, se deberían contemplar los siguientes aspectos:

a) Identificar los requerimientos de seguridad de cada una de las aplicaciones.

b) Identificar toda la información relacionada con las aplicaciones.

c) Establecer criterios coherentes entre esta Política de Control de Acceso y la Política de Clasificación de Información de los diferentes sistemas y redes (Ver 2. Clasificación y Control de Activos).



Comité de Seguridad de la Información

Coordinación General

- d) Identificar la legislación aplicable y las obligaciones contractuales con respecto a la protección del acceso a datos y servicios.
- e) Definir los perfiles de acceso de usuarios estándar, comunes a cada categoría de puestos de trabajo.
- f) Administrar los derechos de acceso en un ambiente distribuido y de red, que reconozcan todos los tipos de conexiones disponibles.

6.1.2 Reglas de Control de Acceso. Las reglas de control de acceso especificadas deberían:

- a) Indicar expresamente si las reglas son obligatorias u optativas
- b) Establecer reglas sobre la premisa “Todo debe estar prohibido a menos que se permita expresamente” y no sobre la premisa inversa de “Todo está permitido a menos que se prohíba expresamente”.
- c) Controlar los cambios en los rótulos de información que son iniciados automáticamente por herramientas de procesamiento de información, de aquellos que son iniciados a discreción del usuario (Ver 5. Clasificación y Control de Activos).
- d) Controlar los cambios en los permisos de usuario que son iniciados automáticamente por el sistema de información y aquellos que son iniciados por el administrador.
- e) Controlar las reglas que requieren la aprobación del administrador o del Propietario de la Información de que se trate, antes de entrar en vigencia, y aquellas que no requieren aprobación

6.2. Administración de Accesos de Usuarios

6.2.1. **Registración de Usuarios.** Se debería definir un procedimiento formal de registro de usuarios para otorgar y revocar el acceso a todos los sistemas, bases de datos y servicios de información multiusuario, el cual debería comprender:

- a) Utilizar identificadores de usuario únicos, de manera que se pueda identificar a los usuarios por sus acciones evitando la existencia de múltiples perfiles de acceso para un mismo empleado. El uso de identificadores grupales sólo debería ser permitido cuando sean convenientes para el trabajo a desarrollar debido a razones operativas.
- b) Verificar que el usuario tiene autorización del Propietario de la Información para el uso del sistema, base de datos o servicio de información.
- c) Verificar que el nivel de acceso otorgado es adecuado para el propósito de la función del usuario y es coherente con la Política de Seguridad de la Universidad, por ejemplo que no comprometiese la separación de tareas.
- d) Entregar a los usuarios un detalle escrito de sus derechos de acceso.



Comité de Seguridad de la Información

Coordinación General

- e) Requerir que los usuarios firmen declaraciones señalando que comprenden y aceptan las condiciones para el acceso.
- f) Garantizar que los proveedores de servicios no otorguen acceso hasta que se hayan completado los procedimientos de autorización.
- g) Mantener un registro formal de todas las personas registradas para utilizar el servicio.
- h) Cancelar inmediatamente los derechos de acceso de los usuarios que cambiaron sus tareas, o de aquellos a los que se les revocó la autorización, se desvincularon del Organismo o sufrieron la pérdida/robo de sus credenciales de acceso.
- i) Efectuar revisiones periódicas con el objeto de:
 - cancelar identificadores y cuentas de usuario redundantes
 - inhabilitar cuentas inactivas por más de un período determinado
 - eliminar cuentas inactivas por más de un período determinadoEn el caso de existir excepciones, deberían ser debidamente justificadas y aprobadas.
- j) Garantizar que los identificadores de usuario redundantes no se asignen a otros usuarios.
- k) Incluir cláusulas en los contratos de personal y de servicios que especifiquen sanciones si el personal o los agentes que prestan un servicio intentan accesos no autorizados.

6.2.2. Administración de Privilegios. Se debería limitar y controlar la asignación y uso de privilegios, debido a que el uso inadecuado de los privilegios del sistema resulta frecuentemente, el factor más importante que contribuye a la falla de los sistemas a los que se ha accedido ilegalmente. Los sistemas multiusuario que requieran protección contra accesos no autorizados, deberían prever una asignación de privilegios controlada mediante un proceso de autorización formal. Se deberían tener en cuenta los siguientes pasos:

- a) Identificar los privilegios asociados a cada producto del sistema, por ejemplo sistema operativo, sistema de administración de bases de datos y aplicaciones, y las categorías de personal a las cuales deben asignarse los productos.
- b) Asignar los privilegios a individuos sobre la base de la necesidad de uso y evento por evento, por ejemplo el requerimiento mínimo para su rol funcional.
- c) Mantener un proceso de autorización y un registro de todos los privilegios asignados. Los privilegios no deben ser otorgados hasta que se haya completado el proceso formal de autorización.
- d) Establecer un período de vigencia para el mantenimiento de los privilegios (en base a la utilización que se le dará a los mismos) luego del cual los mismos serán revocados.



Comité de Seguridad de la Información

Coordinación General

e) Promover el desarrollo y uso de rutinas del sistema para evitar la necesidad de otorgar privilegios a los usuarios.

Los Propietarios de Información deberían ser los encargados de aprobar la asignación de privilegios a usuarios y solicitar su implementación, lo cual debería ser supervisado por el Responsable de Seguridad Informática.

6.2.3. Administración de Contraseñas de Usuario. La asignación de contraseñas se debería controlar a través de un proceso de administración formal, mediante el cual debería respetar los siguientes pasos:

- a) Requerir que los usuarios firmen una declaración por la cual se comprometen a mantener sus contraseñas personales en secreto y las contraseñas de los grupos de trabajo exclusivamente entre los miembros del grupo. Esta declaración bien puede estar incluida en el Compromiso de Confidencialidad (Ver 3.1.3. Compromiso de Confidencialidad)
- b) Garantizar que los usuarios cambien las contraseñas iniciales que les han sido asignadas la primera vez que ingresan al sistema. Las contraseñas provisionales, que se asignan cuando los usuarios olvidan su contraseña, sólo debe suministrarse una vez identificado el usuario.
- c) Generar contraseñas provisionales seguras para otorgar a los usuarios. Se debe evitar la participación de terceros o el uso de mensajes de correo electrónico sin protección (texto claro) en el mecanismo de entrega de la contraseña y los usuarios deben dar acuse de recibo cuando la reciban.
- d) Almacenar las contraseñas sólo en sistemas informáticos protegidos.
- e) Utilizar otras tecnologías de autenticación y autorización de usuarios, como ser la biométrica (por ejemplo verificación de huellas dactilares), verificación de firma, uso de autenticadores de hardware (como las tarjetas de circuito integrado), etc. El uso de esas herramientas debería disponerse cuando la evaluación de riesgos realizada por el Responsable de Seguridad Informática conjuntamente con el Responsable del Área de Informática y el Propietario de la Información lo determine necesario (o lo justifique).
- f) Configurar los sistemas de tal manera que:- las contraseñas tengan un tamaño no menor a 8 caracteres,- suspendan o bloqueen permanentemente al usuario luego de un número determinado de intentos de entrar con una contraseña incorrecta, solicitar el cambio de la contraseña en forma periódica, impedir que las últimas contraseñas sean reutilizadas, establecer un tiempo de vida mínimo de días para la vigencia de las contraseñas.

6.2.4. Administración de Contraseñas Críticas. Se deberían definir procedimientos para la administración de dichas contraseñas críticas, que contemplen lo siguiente:

- a) Las causas que justifiquen el uso de contraseñas críticas, así como el nivel de autorización requerido.



Comité de Seguridad de la Información

Coordinación General

- b) Las contraseñas seleccionadas serán seguras, y su definición será efectuada como mínimo por dos personas, de manera que ninguna de ellas conozca la contraseña completa.
- c) Las contraseñas y los nombres de las cuentas críticas a las que pertenecen serán resguardadas debidamente.
- d) La utilización de las contraseñas críticas será registrada, documentando las causas que determinaron su uso, así como el responsable de las actividades que se efectúen con la misma.
- e) Cada contraseña crítica se renovará una vez utilizada y se definirá un período luego del cual la misma será renovada en caso de que no se la haya utilizado.
- f) Se registrarán todas las actividades que se efectúen con las cuentas críticas para luego ser revisadas. Dicho registro será revisado posteriormente por el Responsable de Seguridad.

6.2.5. Revisión de Derechos de Acceso de Usuarios. Se deberían contemplar los siguientes controles:

- a) Revisar los derechos de acceso de los usuarios a intervalos de 6 meses.
- b) Revisar las autorizaciones de privilegios especiales de derechos de acceso a intervalos de 3 meses.
- c) Revisar las asignaciones de privilegios a intervalos de 6 meses, a fin de garantizar que no se obtengan privilegios no autorizados

6.3 Responsabilidades del Usuario

6.3.1. Uso de Contraseñas. Se deberían implementar las siguientes directivas, con el fin de poner en conocimiento de los usuarios para su cumplimiento, en función que las mismas constituyen un medio de validación y autenticación de la identidad de un usuario y consecuentemente un medio para establecer derechos de acceso a las instalaciones o servicios de procesamiento de información.

- a) Mantener las contraseñas en secreto.
- b) Pedir el cambio de la contraseña siempre que exista un posible indicio de compromiso del sistema o de las contraseñas.
- c) Seleccionar contraseñas de calidad, de acuerdo a las prescripciones informadas por el Responsable del Activo de Información de que se trate, que:
 - 1. Sean fáciles de recordar.
 - 2. No estén basadas en algún dato que otra persona pueda adivinar u obtener fácilmente mediante información relacionada con la persona, por ejemplo nombres,



Comité de Seguridad de la Información

Coordinación General

números de teléfono, fecha de nacimiento, etc.

3. No tengan caracteres idénticos consecutivos o grupos totalmente numéricos o totalmente alfabéticos.

d) Cambiar las contraseñas cada vez que el sistema se lo solicite y evitar reutilizar o reciclar viejas contraseñas.

e) Cambiar las contraseñas provisorias en el primer inicio de sesión ("log on").

f) Evitar incluir contraseñas en los procesos automatizados de inicio de sesión, por ejemplo, aquellas almacenadas en una tecla de función o macro.

g) Notificar de acuerdo a lo establecido en 3.3.1 – "Comunicación de Incidentes Relativos a la Seguridad", cualquier incidente de seguridad relacionado con sus contraseñas: pérdida, robo o indicio de pérdida de confidencialidad.

Si los usuarios necesitaran acceder a múltiples servicios o plataformas y se requiere que mantengan múltiples contraseñas, se debería notificar a los mismos que pueden utilizar una única contraseña para todos los servicios que brinden un nivel adecuado de protección de las contraseñas almacenadas y en tránsito.

6.3.2. Equipos Desatendidos en Áreas de Usuarios. Se deberían desarrollar tareas de concientización de todos los usuarios y contratistas, acerca de los requerimientos y procedimientos de seguridad, para la protección de equipos desatendidos, así como de sus funciones en relación a la implementación de dicha protección. Para ello debería considerarse el cumplimiento de las siguientes pautas:

a) Concluir las sesiones activas al finalizar las tareas, a menos que puedan protegerse mediante un mecanismo de bloqueo adecuado, por ejemplo, un protector de pantalla protegido por contraseña.

b) Proteger las PC's o terminales contra usos no autorizados mediante un bloqueo de seguridad o control equivalente, por ejemplo, contraseña de acceso cuando no se utilizan.

6.4. Control de Acceso a la Red

6.4.1 Política de Utilización de los Servicios de Red. Se debería controlar el acceso a los servicios de red tanto internos como externos. Para ello, se deberían desarrollar procedimientos para la activación y desactivación de derechos de acceso a las redes, los cuales comprenderían:

a) Identificar las redes y servicios de red a los cuales se permite el acceso.

b) Realizar normas y procedimientos de autorización para determinar las personas y las redes y servicios de red a los cuales se les otorgará el acceso.

c) Establecer controles y procedimientos de gestión para proteger el acceso a las conexiones y servicios de red.



Comité de Seguridad de la Información

Coordinación General

6.4.2 Camino Forzado. Se debería limitar las opciones de elección de la ruta entre la terminal de usuario y los servicios a los cuales el mismo se encuentra autorizado a acceder, mediante la implementación de controles en diferentes puntos de la misma. A continuación se enumeran algunos ejemplos a considerar en caso de implementar estos controles a los sistemas existentes:

- a) Asignar números telefónicos o líneas, en forma dedicada.
- b) Establecer la conexión automática de puertos a gateways de seguridad o a sistemas de aplicación específicos.
- c) Limitar las opciones de menú y submenú de cada uno de los usuarios.
- d) Evitar la navegación ilimitada por la red.
- e) Imponer el uso de sistemas de aplicación y/o gateways de seguridad específicos para usuarios externos de la red.
- f) Controlar activamente las comunicaciones con origen y destino autorizados a través de un gateway, por ejemplo utilizando firewalls.
- g) Restringir el acceso a redes, estableciendo dominios lógicos separados, por ejemplo, redes privadas virtuales para grupos de usuarios dentro o fuera de la Universidad.

6.4.3. Autenticación de Usuarios para Conexiones Externas. Se debería realizar una evaluación de riesgos a fin de determinar el mecanismo de autenticación que corresponda en cada caso. La autenticación de usuarios remotos podría llevarse a cabo utilizando:

- a) Un método de autenticación físico (por ejemplo tokens de hardware), para lo que debería implementarse un procedimiento que incluyese:
 - Asignación de la herramienta de autenticación.
 - Registro de los poseedores de autenticadores.
 - Mecanismo de rescate al momento de la desvinculación del personal al que se le otorgó.
 - Método de revocación de acceso del autenticador, en caso de compromiso de seguridad.
- b) Un protocolo de autenticación (por ejemplo desafío / respuesta), para lo que debería implementarse un procedimiento que incluyese:
 - Establecimiento de las reglas con el usuario.
 - Establecimiento de un ciclo de vida de las reglas para su renovación.
- c) También pueden utilizarse líneas dedicadas privadas o una herramienta de verificación de la dirección del usuario de red, a fin de constatar el origen de la conexión.

6.4.4. Autenticación de Nodos. Las conexiones a sistemas informáticos remotos deberían ser autenticadas. Esto es particularmente importante si la conexión utiliza una red que está fuera de



Comité de Seguridad de la Información

Coordinación General

control de la gestión de seguridad de la Universidad. En el punto anterior se mencionan algunos ejemplos de autenticación y de cómo puede lograrse. La autenticación de nodos puede servir como un medio alternativo de autenticación de grupos de usuarios remotos, cuando éstos están conectados a un servicio informático seguro y compartido.

6.4.5. Protección de los Puertos (Ports) de Diagnóstico Remoto. Los puertos de diagnóstico proporcionan un medio de acceso no autorizado. Por consiguiente, deberían ser protegidos por un mecanismo de seguridad apropiado. Con las mismas características del punto “Autenticación de Usuarios para Conexiones Externas”. También para este caso deberá tenerse en cuenta el punto “Camino Forzado”.

6.4.6. Subdivisión de Redes. Se deberían definir y documentar los perímetros de seguridad que sean convenientes, que se implementarán mediante la instalación de “gateways” con funcionalidades de “firewall” o redes privadas virtuales para filtrar el tráfico entre los dominios (Ver 6.4.8. Control de Conexión a la Red y 6.4.9. Control de Ruteo de Red) y para bloquear el acceso no autorizado, de acuerdo a la Política de Control de Accesos (Ver 6.1. Requerimientos para el Control de Acceso).

La subdivisión en dominios de la red debería tomar en cuenta criterios como los requerimientos de seguridad comunes de grupos de integrantes de la red, la mayor exposición de un grupo a peligros externos, separación física, u otros criterios de aglutinamiento o segregación preexistentes.

Basándose en la Política de Control de Accesos y los requerimientos de acceso (Ver 6.1. Requerimientos para el Control de Acceso), se debería evaluar el costo relativo y el impacto en el desempeño que ocasione la implementación de enrutadores o gateways adecuados (Ver 6.4.8. Control de Conexión a la Red y 6.4.9. Control de Ruteo de Red) para subdividir la red.

6.4.7. Acceso a Internet. Se debería evaluar la conveniencia de generar un registro de los accesos de los usuarios a Internet, con el objeto de realizar revisiones de los accesos efectuados o analizar casos particulares. Dicho control debería ser comunicado a los usuarios, de acuerdo a lo establecido en el punto “Compromiso de Confidencialidad”.

6.4.8. Control de Conexión a la Red. Se podrán implementar controles para limitar la capacidad de conexión de los usuarios, de acuerdo a las políticas que se establecen a tal efecto. Dichos controles se podrán implementar en los “gateways” que separan los diferentes dominios de la red. (Ver 6.4.6. Subdivisión de Redes). Algunos de los entornos a las que deben implementarse restricciones son:

- a) Correo electrónico.
- b) Transferencia de archivos.
- c) Acceso interactivo.
- d) Acceso a la red fuera del horario laboral.

6.4.9. Control de Ruteo de Red. Se debería incorporar controles de ruteo, para asegurar que las conexiones informáticas y los flujos de información no violen la Política de Control de Accesos.



Comité de Seguridad de la Información

Coordinación General

Estos controles deberían contemplar mínimamente, la verificación positiva de direcciones de origen y destino. Adicionalmente, para este objetivo, pueden utilizarse diversos métodos incluyendo entre otros autenticación de protocolos de ruteo, ruteo estático, traducción de direcciones y listas de control de acceso.

6.4.10. Seguridad de los Servicios de Red. Se deberían definir pautas para garantizar la seguridad de los servicios de red de la Universidad, Para ello se debería tener en cuenta las siguientes directivas:

- Mantener instalados y habilitados sólo aquellos servicios que sean utilizados.
- Controlar el acceso lógico a los servicios, tanto a su uso como a su administración.
- Configurar cada servicio de manera segura, evitando las vulnerabilidades que pudieran presentar.
- Instalar periódicamente las actualizaciones de seguridad.

Dicha configuración será revisada periódicamente.

6.5. Control de Acceso al Sistema Operativo

6.5.1. Identificación Automática de Terminales. Se debería realizar una evaluación de riesgos a fin de determinar el método de protección adecuado para el acceso al Sistema Operativo. Si del análisis realizado surgiera la necesidad de proveer un método de identificación de terminales, se debería redactar un procedimiento que indique:

- a) El método de identificación automática de terminales utilizado.
- b) El detalle de transacciones permitidas por terminal.

6.5.2. Procedimientos de Conexión de Terminales. Se debería definir un proceso de conexión seguro, este será diseñado para minimizar la oportunidad de acceso no autorizado. El procedimiento de identificación debería:

- a) Mantener en secreto los identificadores de sistemas o aplicaciones hasta tanto se halla llevado a cabo exitosamente el proceso de conexión.
- b) Desplegar un aviso general advirtiendo que sólo los usuarios autorizados pueden acceder a la computadora.
- c) Evitar dar mensajes de ayuda que pudieran asistir a un usuario no autorizado durante el procedimiento de conexión.
- d) Validar la información de la conexión sólo al completarse la totalidad de los datos de entrada. Si surge una condición de error, el sistema no debe indicar que parte de los datos es correcta o incorrecta.
- e) Limitar el número de intentos de conexión no exitosos permitidos y:



Comité de Seguridad de la Información

Coordinación General

- Registrar los intentos no exitosos.
 - Impedir otros intentos de identificación, una vez superado el límite permitido.
 - Desconectar conexiones de comunicaciones de datos.
- f) Limitar el tiempo máximo permitido para el procedimiento de conexión. Si este es excedido, el sistema debe finalizar la conexión.
- g) Desplegar la siguiente información, al completarse una conexión exitosa:
- Fecha y hora de la conexión exitosa anterior.
 - Detalles de los intentos de conexión no exitosos desde la última conexión exitosa.

6.5.3. Identificación y Autenticación de los Usuarios. Se debería asignar a todos los usuarios, un identificador único (ID de usuario). Los identificadores de usuarios no darán ningún indicio del nivel de privilegio otorgado. En circunstancias excepcionales, cuando existe un claro beneficio para la Universidad, podría utilizarse un identificador compartido para un grupo de usuarios o una tarea específica. Para casos de esta índole, debería documentarse la justificación y aprobación del Propietario de la Información de que se trate. Si se utilizara un método de autenticación físico (por ejemplo autenticadores de hardware), debería implementarse un procedimiento que incluya:

- a) Asignar la herramienta de autenticación.
- b) Registrar los poseedores de autenticadores.
- c) Rescatar el autenticador al momento de la desvinculación del personal al que se le otorgó.
- d) Revocar el acceso del autenticador, en caso de compromiso de seguridad.

6.5.4. Sistema de Administración de Contraseñas. Se debería establecer un sistema de administración de contraseñas, contemplando lo siguiente:

- a) Imponer el uso de contraseñas individuales para determinar responsabilidades.
- b) Permitir que los usuarios seleccionen y cambien sus propias contraseñas (luego de cumplido el plazo mínimo de mantenimiento de las mismas) e incluir un procedimiento de confirmación para contemplar los errores de ingreso.
- c) Imponer una selección de contraseñas de calidad según lo señalado en el punto "Uso de Contraseñas".
- d) Imponer cambios en las contraseñas en aquellos casos en que los usuarios mantengan sus propias contraseñas, según lo señalado en el punto "Uso de Contraseñas".
- e) Obligar a los usuarios a cambiar las contraseñas provisionales en su primer procedimiento de identificación, en los casos en que ellos seleccionen sus contraseñas.
- f) Mantener un registro de las últimas contraseñas utilizadas por el usuario, y evitar la



Comité de Seguridad de la Información

Coordinación General

reutilización de las mismas.

- g) Evitar mostrar las contraseñas en pantalla, cuando son ingresadas.
- h) Almacenar en forma separada los archivos de contraseñas y los datos de sistemas de aplicación.
- i) Almacenar las contraseñas en forma cifrada utilizando un algoritmo de cifrado unidireccional.
- j) Modificar todas las contraseñas predeterminadas por el vendedor, una vez instalado el software y el hardware (por ejemplo claves de impresoras, hubs, routers, etc.).
- k) Garantizar que el medio utilizado para acceder/utilizar el sistema de contraseñas, asegure que no se tenga acceso a información temporal o en tránsito de forma no protegida

6.5.5. Uso de utilitarios de Sistema. Se debería limitar y controlar minuciosamente el uso de los programas utilitarios, considerando los siguientes controles:

- a) Utilizar procedimientos de autenticación para utilitarios del sistema.
- b) Separar entre utilitarios del sistema y software de aplicaciones.
- c) Limitar el uso de utilitarios del sistema a la cantidad mínima viable de usuarios fiables y autorizados.
- d) Evitar que personas ajenas a la Universidad tomen conocimiento de la existencia y modo de uso de los utilitarios instalados en las instalaciones informáticas.
- e) Establecer autorizaciones para uso ad hoc de utilitarios de sistema.
- f) Limitar la disponibilidad de utilitarios de sistema, por ejemplo durante el transcurso de un cambio autorizado.
- g) Registrar todo uso de utilitarios del sistema.
- h) Definir y documentar los niveles de autorización para utilitarios del sistema.
- i) Remover todo el software basado en utilitarios y software de sistema innecesarios.

6.5.6. Alarmas Silenciosas para la Protección de los Usuarios. Se debería considerar la provisión de alarmas silenciosas para los usuarios que podrían ser objetos de coerción. La decisión de suministrar una alarma de esta índole se basará en una evaluación de riesgos. En este caso, se definirán y asignarán funciones y procedimientos para responder a la utilización de una alarma silenciosa.

6.5.7. Desconexión de Terminales por Tiempo Muerto . Se debería definir cuáles se consideran terminales de alto riesgo o que sirven a sistemas de alto riesgo. Las mismas se apagarán después de un periodo definido de inactividad, por un lapso que responderá a los riesgos de seguridad del área y de la información que maneje la terminal.. Para las PC's, se debería implementar la desconexión por tiempo muerto, que limpie la pantalla y evite el acceso no autorizado, pero que no cierra las sesiones de aplicación o de red. Por otro lado, si un usuario debe abandonar



Comité de Seguridad de la Información

Coordinación General

su puesto de trabajo momentáneamente, activará protectores de pantalla con contraseñas a los efectos de evitar que terceros puedan ver su trabajo o continuar con la sesión de usuario habilitada.

6.5.8. Limitación del Horario de Conexión. Se debería implementar un control de esta índole para aplicaciones informáticas sensibles, especialmente aquellas terminales instaladas en ubicaciones de alto riesgo. Entre los controles que se deben aplicar, se enuncian:

- a) Utilizar lapsos predeterminados, por ejemplo para transmisiones de archivos en lote, o sesiones interactivas periódicas de corta duración.
- b) Limitar los tiempos de conexión al horario normal de oficina, de no existir un requerimiento operativo de horas extras o extensión horaria.
- c) Documentar debidamente los agentes que no tienen restricciones horarias y las razones de su autorización. También cuando el Propietario de la Información autorice excepciones para una extensión horaria ocasional

6.6. Control de Acceso a las Aplicaciones

6.6.1. Restricción del Acceso a la Información. Se deberían aplicar los siguientes controles, para brindar apoyo a los requerimientos de limitación de accesos:

- a) Proveer una interfaz para controlar el acceso a las funciones de los sistemas de aplicación.
- b) Restringir el conocimiento de los usuarios acerca de la información o de las funciones de los sistemas de aplicación a las cuales no sean autorizados a acceder, con la adecuada edición de la documentación de usuario.
- c) Controlar los derechos de acceso de los usuarios, por ejemplo, lectura, escritura, supresión y ejecución.
- d) Garantizar que las salidas de los sistemas de aplicación que administran información sensible, contengan sólo la información que resulte pertinente para el uso de la salida, y que la misma se envíe solamente a las terminales y ubicaciones autorizadas.
- e) Revisar periódicamente dichas salidas a fin de garantizar la remoción de la información redundante.
- f) Restringir el acceso a la información por fuera del sistema encargado de su procesamiento, es decir, la modificación directa del dato almacenado.

6.6.2. Aislamiento de los Sistemas Sensibles. Se debería evaluar la aplicación de las siguientes consideraciones:

- a) Identificar y documentar claramente la sensibilidad de un sistema de aplicación. Esta tarea será llevada a cabo por el administrador de la aplicación (Ver 2. Clasificación y Control



Comité de Seguridad de la Información

Coordinación General

de Activos).

b) Identificar y acordar con el administrador de la aplicación sensible cuando la aplicación ha de ejecutarse en un ambiente compartido, los sistemas de aplicación con los cuales ésta compartirá los recursos.

c) Coordinar qué servicios estarán disponibles en el entorno donde se ejecutará la aplicación, de acuerdo a los requerimientos de operación y seguridad especificados por el administrador de la aplicación.

d) Considerar la seguridad en la administración de las copias de respaldo de la información que procesan las aplicaciones.

e) Considerar las mismas precauciones de seguridad y privacidad, en la elaboración del plan de continuidad y/o contingencia de la ejecución de la aplicación. Ejemplo: el equipamiento alternativo o las instalaciones de emergencia donde restablecer la aplicación.

6.7. Monitoreo del Acceso y Uso de los Sistemas

6.7.1. Registro de Eventos. Se deberían generar registros de auditoría que contengan excepciones y otros eventos relativos a la seguridad. En todos los casos, los registros de auditoría serán archivados preferentemente en un equipo diferente al que los genere y conforme los requerimientos de la Política de Retención de Registros. Los Propietarios de la Información junto con la Unidad de Auditoría Interna o en su defecto quien sea propuesto por el Comité de Seguridad de la Información, deberían definir un cronograma de depuración de registros en línea en función a normas vigentes y a sus propias necesidades.

6.7.2. Monitoreo del Uso de los Sistemas

6.7.2.1. Procedimientos y Áreas de Riesgo. Se debería desarrollar procedimientos para monitorear el uso de las instalaciones de procesamiento de la información, a fin de garantizar que los usuarios sólo estén desempeñando actividades que hayan sido autorizadas explícitamente. Todos los empleados deberían conocer el alcance preciso del uso adecuado de los recursos informáticos, y estar advertidos de que determinadas actividades pueden ser objeto de control y monitoreo. El alcance de estos procedimientos debería corresponderse a la evaluación de riesgos. Entre las áreas que deberían tenerse en cuenta se enumeran las siguientes:

1. Identificación del usuario.
2. Fecha y hora de eventos clave.
3. Tipos de eventos.
4. Archivos a los que se accede.
5. Utilitarios y programas utilizados.



Comité de Seguridad de la Información

Coordinación General

Todas las operaciones con privilegio, como:

1. Utilización de cuenta de supervisor.
2. Inicio y cierre del sistema.
3. Conexión y desconexión de dispositivos de Ingreso y Salida de información o que permitan copiar datos.
4. Cambio de fecha/hora.
5. Cambios en la configuración de la seguridad.
6. Alta de servicios.

Intentos de acceso no autorizado, como:

1. Intentos fallidos.
2. Violaciones de la Política de Accesos y notificaciones para “gateways” de red y “firewalls”.
3. Alertas de sistemas de detección de intrusiones.

Alertas o fallas de sistema como:

1. Alertas o mensajes de consola.
2. Excepciones del sistema de registro.
3. Alarmas del sistema de administración de redes.
4. Accesos remotos a los sistemas.

6.7.2.2. Factores de Riesgo. Se debería manifestar la necesidad de registrar aquellos eventos que consideren críticos para la operatoria que se encuentra bajo su responsabilidad

6.7.2.3. Registro y Revisión de Eventos. Se debería implementar un procedimiento de registro y revisión de los registros de auditoría, orientado a producir un informe de las amenazas detectadas contra los sistemas y los métodos utilizados. La periodicidad de dichas revisiones debería ser definida por los Propietarios de la Información y el Responsable de Seguridad Informática, de acuerdo a la evaluación de Riesgos efectuada.

6.7.3. Sincronización de Relojes. A fin de garantizar la exactitud de los registros de auditoría, al menos los equipos que realicen estos registros, deberían tener una correcta configuración de sus relojes

6.8. Computación Móvil y Trabajo Remoto

6.8.1 Computación Móvil. Se debería desarrollar normas y procedimientos sobre los cuidados especiales a observar ante la posesión de dispositivos móviles, que contemplarán las siguientes



Comité de Seguridad de la Información

Coordinación General

recomendaciones:

- a) Permanecer siempre cerca del dispositivo.
- b) No dejar desatendidos los equipos.
- c) No llamar la atención acerca de portar un equipo valioso.
- d) No poner identificaciones del Organismo en el dispositivo, salvo los estrictamente necesarios.
- e) No poner datos de contacto técnico en el dispositivo.
- f) Mantener cifrada la información clasificada.

Por otra parte, se deberían confeccionar procedimientos que permitiesen al propietario del dispositivo reportar rápidamente cualquier incidente sufrido y mitigar los riesgos a los que eventualmente estuvieran expuestos los sistemas de información de la Universidad los que incluirían:

- a) Revocación de las credenciales afectadas.
- b) Notificación a grupos de Trabajo donde potencialmente se pudieran haber comprometido recursos.

6.8.2. Trabajo Remoto. Se deberían establecer normas y procedimientos para el trabajo remoto, que consideren los siguientes aspectos:

- a) La seguridad física existente en el sitio de trabajo remoto, tomando en cuenta la seguridad física del edificio y del ambiente local.
- b) El ambiente de trabajo remoto propuesto.
- c) Los requerimientos de seguridad de comunicaciones, tomando en cuenta la necesidad de acceso remoto a los sistemas internos de la Universidad, la sensibilidad de la información a la que se accederá y que pasará a través del vínculo de comunicación y la sensibilidad del sistema interno.
- d) La amenaza de acceso no autorizado a información o recursos por parte de otras personas que utilizan el lugar, por ejemplo, familia y amigos.
- e) Evitar la instalación / desinstalación de software no autorizada por la Universidad.

Los controles y disposiciones comprenderían:

- a) Proveer de mobiliario para almacenamiento y equipamiento adecuado para las actividades de trabajo remoto.
- b) Definir el trabajo permitido, el horario de trabajo, la clasificación de la información que se puede almacenar en el equipo remoto desde el cual se accede a la red de la Universidad y los sistemas internos y servicio a los cuales el trabajador remoto está autorizado a acceder.



Comité de Seguridad de la Información
Coordinación General

- c) Proveer de un adecuado equipo de comunicación, con inclusión de métodos para asegurar el acceso remoto.

DESARROLLO Y MANTENIMIENTO DE SISTEMA

7.1 Requerimientos de Seguridad de los Sistemas

7.1.1. Análisis y Especificaciones de los Requerimientos de Seguridad. Se deberían tener en cuenta las siguientes consideraciones:

- a) Definir un procedimiento para que durante las etapas de análisis y diseño del sistema, se incorporen a los requerimientos, los correspondientes controles de seguridad. Este procedimiento debería incluir una etapa de evaluación de riesgos previa al diseño, para definir los requerimientos de seguridad e identificar los controles apropiados. En esta tarea deben participar las áreas usuarias, de sistemas, de seguridad informática y auditoría, especificando y aprobando los controles automáticos a incorporar al sistema y las necesidades de controles manuales complementarios. Las áreas involucradas podrán solicitar certificaciones y evaluaciones independientes para los productos a utilizar.
- b) Evaluar los requerimientos de seguridad y los controles requeridos, teniendo en cuenta que éstos deberían ser proporcionales en costo y esfuerzo al valor del bien que se quiere proteger y al daño potencial que pudiera ocasionar a las actividades realizadas.
- c) Considerar que los controles introducidos en la etapa de diseño, deberían ser significativamente menos costosos de implementar y mantener que aquellos incluidos durante o después de la implementación.

7.2 Seguridad en los Sistemas de Aplicación

7.2.1. Validación de Datos de Entrada. Este procedimiento debería considerar los siguientes controles:

- a) Control de secuencia.
- b) Control de monto límite por operación y tipo de usuario.
- c) Control del rango de valores posibles y de su validez, de acuerdo a criterios predeterminados.
- d) Control de paridad.
- e) Control contra valores cargados en las tablas de datos.
- f) Controles por oposición, de forma tal que quien ingrese un dato no pueda autorizarlo y



Comité de Seguridad de la Información

Coordinación General

viceversa.

Por otra parte, se deberían llevar a cabo las siguientes acciones:

- a) Definir un procedimiento para realizar revisiones periódicas de contenidos de campos claves o archivos de datos, definiendo quién lo realizará, en qué forma, con qué método, quiénes deberán ser informados del resultado, etc.
- b) Definir un procedimiento que explicita las alternativas a seguir para responder a errores de validación en un aplicativo.
- c) Definir un procedimiento que permita determinar las responsabilidades de todo el personal involucrado en el proceso de entrada de datos.

7.2.2. Controles de Procesamiento Interno. Se deberían implementar:

- a) Procedimientos que permitan identificar el uso y localización en los aplicativos, de funciones de incorporación y eliminación que realizan cambios en los datos.
- b) Procedimientos que establezcan los controles y verificaciones necesarios para prevenir la ejecución de programas fuera de secuencia o cuando falle el procesamiento previo.
- c) Procedimientos que establezcan la revisión periódica de los registros de auditoría de forma de detectar cualquier anomalía en la ejecución de las transacciones.
- d) Procedimientos que realicen la validación de los datos generados por el sistema.
- e) Procedimientos que verifiquen la integridad de los datos y del software cargado o descargado entre computadoras.
- f) Procedimientos que controlen la integridad de registros y archivos.
- g) Procedimientos que verifiquen la ejecución de los aplicativos en el momento adecuado.
- h) Procedimientos que aseguren el orden correcto de ejecución de los aplicativos, la finalización programada en caso de falla, y la detención de las actividades de procesamiento hasta que el problema sea resuelto.

7.2.3 Autenticación de Mensajes. Cuando una aplicación tenga previsto el envío de mensajes que contengan información clasificada, se deberían implementar controles criptográficos.

7.2.4. Validación de Datos de Salidas . Se deberían establecer procedimientos para validar la salida de los datos de las aplicaciones, incluyendo:

- a) Comprobaciones de la razonabilidad para probar si los datos de salida son plausibles.
- b) Control de conciliación de cuentas para asegurar el procesamiento de todos los datos.
- c) Provisión de información suficiente, para que el lector o sistema de procesamiento subsecuente determine la exactitud, totalidad, precisión y clasificación de la información.
- d) Procedimientos para responder a las pruebas de validación de salidas.
- e) Definición de las responsabilidades de todo el personal involucrado en el proceso de



Comité de Seguridad de la Información

Coordinación General

salida de datos.

7.3 Controles Criptográficos.

7.3.1. Política de Utilización de Controles Criptográficos. Se deberían utilizar controles criptográficos en los siguientes casos:

1. Para la protección de claves de acceso a sistemas, datos y servicios.
2. Para la transmisión de información clasificada, fuera del ámbito de la Universidad
3. Para el resguardo de información, cuando así surja de la evaluación de riesgos realizada por el Propietario de la Información y el Responsable de Seguridad Informática.

a) Se deberían desarrollar procedimientos respecto de la administración de claves, de la recuperación de información cifrada en caso de pérdida, compromiso o daño de las claves y en cuanto al reemplazo de las claves de cifrado.

b) El Responsable del Área Informática debería proponer la siguiente asignación de funciones:

- Función
- Cargo Implementación de la Política de Controles Criptográficos
- Administración de Claves

7.3.2. Cifrado. Al implementar la Política de la Universidad en materia criptográfica, se deberían considerar los controles aplicables a la exportación e importación de tecnología criptográfica .

7.3.3. Firma Digital. Se deberían tomar recaudos para proteger la confidencialidad de las claves privadas. Asimismo, es importante proteger la integridad de la clave pública. Esta protección debería proveerse mediante el uso de un certificado de clave pública.

7.3.4 Servicio de no Repudio. Estos servicios se deberían utilizar cuando fuese necesario resolver disputas acerca de la ocurrencia de un evento o acción. Su objetivo es proporcionar herramientas para evitar que aquél que haya originado una transacción electrónica niegue haberla efectuado.

7.3.5 Administración de Claves

7.3.5.1. Protección de Claves Criptográficas. Se debería implementar un sistema de administración de claves criptográficas para respaldar su utilización por parte de la Universidad de los dos tipos de técnicas criptográficas, a saber:

a) Técnicas de clave secreta (criptografía simétrica), cuando dos o más actores comparten la misma clave y ésta se utiliza tanto para cifrar información como para descifrarla.

b) Técnicas de clave pública (criptografía asimétrica), cuando cada usuario tiene un par de claves: una clave pública (que puede ser revelada a cualquier persona) utilizada para



Comité de Seguridad de la Información

Coordinación General

cifrar y una clave privada (que debe mantenerse en secreto) utilizada para descifrar. Las claves asimétricas utilizadas para cifrado no deben ser las mismas que se utilizan para firmar digitalmente.

c) Todas las claves serán protegidas contra modificación y destrucción, y las claves secretas y privadas serán protegidas contra copia o divulgación no autorizada. Se aplicarán con éste propósito los algoritmos criptográficos enumerados en el punto 7.3.1. Política de Utilización de Controles Criptográficos Se proporcionará una protección adecuada al equipamiento utilizado para generar, almacenar y archivar claves, considerándolo crítico o de alto riesgo.

7.4 Seguridad de los Archivos del Sistema

7.4.1. Control del Software Operativo. Se debería designar un personal que cumpla la función de implementador, quien tendría como funciones principales:

- a) Coordinar la implementación de modificaciones o nuevos programas en el ambiente de Producción.
- b) Asegurar que los sistemas aplicativos en uso, en el ambiente de Producción, sean los autorizados y aprobados de acuerdo a las normas y procedimientos vigentes.
- c) Instalar las modificaciones, controlando previamente la recepción de la prueba aprobada por parte del Analista Responsable, del sector encargado del testeo y del usuario final.
- d) Rechazar la implementación en caso de encontrar defectos y/o si faltara la documentación estándar establecida.

Otros controles a realizar son:

- a) Guardar sólo los ejecutables en el ambiente de producción.
- b) Llevar un registro de auditoría de las actualizaciones realizadas.
- c) Retener las versiones previas del sistema, como medida de contingencia.
- d) Definir un procedimiento que establezca los pasos a seguir para implementar las autorizaciones y conformes pertinentes, las pruebas previas a realizarse, etc.
- e) Denegar permisos de modificación al implementador sobre los programas fuentes bajo su custodia.
- f) Evitar, que la función de implementador sea ejercida por personal que pertenezca al sector de desarrollo o mantenimiento.

7.4.2 Protección de los Datos de Prueba del Sistema. Se deberían proteger los datos de prueba, estableciendo normas y procedimientos a tal efecto, que contemplen lo siguiente:

- a) Prohibir el uso de bases de datos operativas. En caso contrario se deberían depersonalizar los datos antes de su uso. Aplicar idénticos procedimientos de control de acceso que en la base de producción.
- b) Solicitar autorización formal para realizar una copia de la base operativa como base de



Comité de Seguridad de la Información

Coordinación General

prueba, llevando registro de tal autorización.

c) Eliminar inmediatamente, una vez completadas las pruebas, la información operativa utilizada

7.4.3. Control de Cambios a Datos Operativos. Se debería crear un procedimiento para tratar todos los cambios, ya que estos se consideraran como excepciones, contemplando:

- a) Generar una solicitud formal para la realización de la modificación, actualización o eliminación del dato.
- b) El Propietario de la Información afectada y del Responsable de Seguridad Informática deberían aprobar la ejecución del cambio evaluando las razones por las cuales se solicita.
- c) Generar cuentas de usuario de emergencia para ser utilizadas en la ejecución de excepciones. Las mismas serán protegidas mediante contraseñas, sujetas al procedimiento de administración de contraseñas críticas (Ver 9.2.4. Administración de Contraseñas Críticas) y habilitadas sólo ante un requerimiento de emergencia y por el lapso que ésta dure.
- d) Designar un encargado de implementar los cambios, el cual no debería ser personal del área de Desarrollo. En el caso de que esta función no pueda ser segregada, se deberían aplicar controles adicionales de acuerdo a lo establecido en 8.1.4. Separación de Funciones.
- e) Registrar todas las actividades realizadas con las cuentas de emergencia. Dicho registro será revisado posteriormente por el Responsable de Seguridad Informática.

7.4.4. Control de Acceso a las Bibliotecas de Programas Fuentes. Se debería designar “un Administrador de Programas Fuentes” quien debería tener a los mismos en custodia y deberá:

- Proveer al Área de Desarrollo los programas fuentes solicitados para su modificación, manteniendo en todo momento la correlación programa fuente ejecutable.
 - Llevar un registro actualizado de todos los programas fuentes en uso, indicando nombre del programa, programador, Analista Responsable que autorizó, versión, fecha de última modificación y fecha / hora de compilación y estado (en modificación, en producción).
 - Verificar que el Analista Responsable que autoriza la solicitud de un programa fuente sea el designado para la aplicación, rechazando el pedido en caso contrario. Registrar cada solicitud aprobada.
 - Administrar las distintas versiones de una aplicación.
 - Asegurar que un mismo programa fuente no sea modificado simultáneamente por más de un desarrollador.
- b) Denegar al “administrador de programas fuentes”, permisos de modificación sobre los programas fuentes bajo su custodia.



Comité de Seguridad de la Información

Coordinación General

- c) Establecer que todo programa objeto o ejecutable en producción tenga un único programa fuente asociado que garantice su origen.
- d) Establecer que el implementador de producción efectuará la generación del programa objeto o ejecutable que estará en producción (compilación), a fin de garantizar tal correspondencia.
- e) Desarrollar un procedimiento que garantice que toda vez que se migre a producción el módulo fuente, se cree el código ejecutable correspondiente en forma automática.
- f) Evitar que la función de “administrador de programas fuentes” sea ejercida por personal que pertenezca al sector de desarrollo y/o mantenimiento.
- g) Prohibir la guarda de programas fuentes históricos (que no sean los correspondientes a los programas operativos) en el ambiente de producción.
- h) Prohibir el acceso a todo operador y/o usuario de aplicaciones a los ambientes y a las herramientas que permitan la generación y/o manipulación de los programas fuentes.
- i) Realizar las copias de respaldo de los programas fuentes cumpliendo los requisitos de seguridad establecidos por la Universidad en los procedimientos que surgen de la presente política.

7.5. Seguridad de los Procesos de Desarrollo y Soporte

7.5.1. Procedimiento de Control de Cambios. Se debería establecer un procedimiento que incluya las siguientes consideraciones:

- a) Verificar que los cambios sean propuestos por usuarios autorizados y respete los términos y condiciones que surjan de la licencia de uso.
- b) Mantener un registro de los niveles de autorización acordados.
- c) Solicitar la autorización del Propietario de la Información, en caso de tratarse de cambios a sistemas de procesamiento de la misma.
- d) Identificar todos los elementos que requieren modificaciones (software, bases de datos, hardware).
- e) Revisar los controles y los procedimientos de integridad para garantizar que no serán comprometidos por los cambios.
- f) Obtener aprobación formal por parte del Responsable del Área Informática para las tareas detalladas, antes que comiencen las tareas.
- g) Solicitar la revisión del Responsable de Seguridad Informática para garantizar que no se violen los requerimientos de seguridad que debe cumplir el software.
- h) Efectuar las actividades relativas al cambio en el ambiente de desarrollo.
- i) Obtener la aprobación por parte del usuario autorizado y del área de pruebas mediante



Comité de Seguridad de la Información

Coordinación General

pruebas en el ambiente correspondiente.

- j) Actualizar la documentación para cada cambio implementado, tanto de los manuales de usuario como de la documentación operativa.
- k) Mantener un control de versiones para todas las actualizaciones de software.
- l) Garantizar que la implementación se llevará a cabo minimizando la discontinuidad de las actividades y sin alterar los procesos involucrados.
- m) Informar a las áreas usuarias antes de la implementación de un cambio que pueda afectar su operatoria.
- n) Garantizar que sea el implementador quien efectúe el pasaje de los objetos modificados al ambiente operativo, de acuerdo a lo establecido en "Control del Software Operativo".

7.5.2. Revisión Técnica de los Cambios en el Sistema Operativo. Se debería definir un procedimiento que incluya:

- a) Revisar los procedimientos de integridad y control de aplicaciones para garantizar que no hayan sido comprometidas por el cambio.
- b) Garantizar que los cambios en el sistema operativo sean informados con anterioridad a la implementación.
- c) Asegurar la actualización del Plan de Continuidad de las Actividades de la Universidad.

7.5.3. Restricción del Cambio de Paquetes de Software. Se debería otorgar autorización previa a la modificación de paquetes de software suministrado por proveedores contemplado lo siguiente:

- a) Analizar los términos y condiciones de la licencia a fin de determinar si las modificaciones se encuentran autorizadas.
- b) Determinar la conveniencia de que la modificación sea efectuada por la Universidad, por el proveedor o por un tercero.
- c) Evaluar el impacto que se produce si la Universidad se hace cargo del mantenimiento.
- d) Retener el software original realizando los cambios sobre una copia perfectamente identificada, documentando exhaustivamente por si fuera necesario aplicarlo a nuevas versiones.

7.5.4. Canales Ocultos y Código Malicioso. Se debería:

- a) Adquirir programas a proveedores acreditados o productos ya evaluados.
- b) Examinar los códigos fuentes (cuando sea posible) antes de utilizar los programas.
- c) Controlar el acceso y las modificaciones al código instalado.
- d) Utilizar herramientas para la protección contra la infección del software con código malicioso



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

7.5.5. Desarrollo Externo de Software. Se deberían contemplar los siguientes puntos:

- a) Acuerdos de licencias, propiedad de código y derechos conferidos.
- b) Requerimientos contractuales con respecto a la calidad del código y la existencia de garantías.
- c) Procedimientos de certificación de la calidad y precisión del trabajo llevado a cabo por el proveedor, que incluyan auditorías, revisión de código para detectar código malicioso, verificación del cumplimiento de los requerimientos de seguridad del software establecidos, etc.
- d) Verificación del cumplimiento de las condiciones de seguridad contempladas en el punto 4.3.1. Requerimientos de Seguridad en Contratos de Tercerización
- e) Acuerdos de custodia de los fuentes del software (y cualquier otra información requerida) en caso de quiebra de la tercera parte.

ADMINISTRACIÓN DE LA CONTINUIDAD DE LAS ACTIVIDADES DE LA UNIVERSIDAD

Se deberían revisar periódicamente los planes bajo su incumbencia, como así también identificar cambios en las disposiciones relativas a las actividades de la Universidad aún no reflejadas en los planes de continuidad. De cada plan, se debería verificar el cumplimiento de los procedimientos implementados para llevar a cabo las acciones contempladas en cada plan de continuidad.

El Comité de Seguridad de la Información debería tener a cargo la coordinación del proceso de administración de la continuidad de la operatoria de los sistemas de tratamiento de información de la Universidad frente a interrupciones imprevistas, lo cual incluiría las siguientes funciones:

- Identificar y priorizar los procesos críticos de las actividades de la Universidad.
- Asegurar que todos los integrantes de la Universidad comprendan los riesgos que la misma enfrenta, en términos de probabilidad de ocurrencia e impacto de posibles amenazas, así como los efectos que una interrupción puede tener en la actividad de la Universidad.
- Elaborar y documentar una estrategia de continuidad de las actividades de la Universidad consecuente con los objetivos y prioridades acordados.
- Proponer planes de continuidad de las actividades de la Universidad de conformidad con la estrategia de continuidad acordada.



Comité de Seguridad de la Información

Coordinación General

- Establecer un cronograma de pruebas periódicas de cada uno de los planes de contingencia, proponiendo una asignación de funciones para su cumplimiento.
- Coordinar actualizaciones periódicas de los planes y procesos implementados.
- Considerar la contratación de seguros que podrían formar parte del proceso de continuidad de las actividades de la Universidad.
- Proponer las modificaciones a los planes de contingencia.

8.1. Proceso de la Administración de la Continuidad de la Universidad . El Comité de Seguridad debería tener a cargo la coordinación del proceso de administración de la continuidad de la operatoria de los sistemas de tratamiento de información de la Universidad frente a interrupciones imprevistas, lo cual incluiría las siguientes funciones:

- a) Identificar y priorizar los procesos críticos de las actividades de la Universidad.
- b) Asegurar que todos los integrantes de la Universidad comprendan los riesgos que la misma enfrenta, en términos de probabilidad de ocurrencia e impacto de posibles amenazas, así como los efectos que una interrupción puede tener en la actividad de la Universidad.
- c) Elaborar y documentar una estrategia de continuidad de las actividades de la Universidad consecuente con los objetivos y prioridades acordados.
- d) Proponer planes de continuidad de las actividades de la Universidad de conformidad con la estrategia de continuidad acordada.
- e) Establecer un cronograma de pruebas periódicas de cada uno de los planes de contingencia, proponiendo una asignación de funciones para su cumplimiento.
- f) Coordinar actualizaciones periódicas de los planes y procesos implementados.

8.2. Continuidad de las Actividades y Análisis de los Impactos . Se debería contar con un Plan de Continuidad de las Actividades de la Universidad que contemple los siguientes puntos:

- Identificar los eventos (amenazas) que puedan ocasionar interrupciones en los procesos de las actividades.
- Evaluar los riesgos, Dicha evaluación debería identificar los recursos críticos, los impactos producidos por una interrupción, los tiempos de interrupción aceptables o permitidos, y debe especificar las prioridades de recuperación
- Identificar los controles preventivos, como por ejemplo sistemas de supresión de fuego, detectores de humo y fuego, contenedores resistentes al calor y a prueba de agua para los medios de backup, los registros no electrónicos vitales, etc.



Comité de Seguridad de la Información
Coordinación General

8.3. Elaboración e Implementación de los Planes de Continuidad de las Actividades de la Universidad. El proceso de planificación de la continuidad de las actividades debería considerar los siguientes puntos:

- a) Identificar y acordar respecto a todas las funciones y procedimientos de emergencia.
- b) Analizar los posibles escenarios de contingencia y definir las acciones correctivas a implementar en cada caso.
- c) Implementar procedimientos de emergencia para permitir la recuperación y restablecimiento en los plazos requeridos. Se debe dedicar especial atención a la evaluación de las dependencias de actividades externas y a los contratos vigentes.
- d) Documentar los procedimientos y procesos acordados.
- e) Instruir adecuadamente al personal, en materia de procedimientos y procesos de emergencia acordados, incluyendo el manejo de crisis.
- f) Instruir al personal involucrado en los procedimientos de reanudación y recuperación en los siguientes temas:
 - 1. Objetivo del plan.
 - 2. Mecanismos de coordinación y comunicación entre equipos (personal involucrado).
 - 3. Procedimientos de divulgación.
 - 4. Requisitos de la seguridad.
 - 5. Procesos específicos para el personal involucrado.
 - 6. Responsabilidades individuales.
- g) Probar y actualizar los planes.

8.4. Marco para la Planificación de la Continuidad de las Actividades de la Universidad. El marco para la planificación de la continuidad de las actividades de la Universidad, se deberían tener en cuenta los siguientes puntos:

- a) Prever las condiciones de implementación de los planes que describan el proceso a seguir (cómo evaluar la situación, qué personas estarán involucradas, etc.) antes de poner en marcha los mismos.
- b) Definir los procedimientos de emergencia que describan las acciones a emprender una vez ocurrido un incidente que ponga en peligro las operaciones de la Universidad y/o la vida humana. Esto debería incluir disposiciones con respecto a la gestión de las relaciones públicas y a vínculos eficaces a establecer con las autoridades públicas pertinentes, por ejemplo, la policía, bomberos y autoridades locales.
- c) Realizar los procedimientos de emergencia que describan las acciones a emprender para el



Comité de Seguridad de la Información

Coordinación General

traslado de actividades esenciales de la Universidad o de servicios de soporte a ubicaciones transitorias alternativas, y para el restablecimiento de los procesos en los plazos requeridos.

d) Redactar los procedimientos de recuperación que describan las acciones a emprender para restablecer las operaciones normales de la Universidad.

e) Definir un cronograma de mantenimiento que especifique cómo y cuándo será probado el plan, y el proceso para el mantenimiento del mismo.

f) Efectuar actividades de concientización e instrucción al personal, diseñadas para propiciar la comprensión de los procesos de continuidad las actividades y garantizar que los procesos sigan siendo eficaces.

g) Documentar las responsabilidades y funciones de las personas, describiendo los responsables de la ejecución de cada uno de los componentes del plan y las vías de contacto posibles. Se deben mencionar alternativas cuando corresponda. Es de suma importancia definir a un responsable de declarar el estado de contingencia, lo cual daría inicio al plan.

8.5. Ensayo, Mantenimiento y Reevaluación de los Planes de Continuidad de la Universidad.

Debido a que los planes de continuidad de las actividades de la Universidad pueden fallar, por suposiciones incorrectas, errores o cambios en el equipamiento, se deberían establecer las siguientes pautas de acción:

- El Comité de Seguridad de la Información debería establecer un cronograma de pruebas periódicas de cada uno de los planes de contingencia.
- El cronograma debería indicar quienes son los responsables de llevar a cabo cada una de las pruebas y de elevar el resultado obtenido al citado Comité.

Se deberían utilizar diversas técnicas para garantizar que los planes de contingencia funcionarán ante un hecho real, y éstas deberían incluir por lo menos:

- a) Efectuar pruebas de discusión de diversos escenarios (discutiendo medidas para la recuperación las actividades utilizando ejemplos de interrupciones).
- b) Realizar simulaciones (especialmente para entrenar al personal en el desempeño de sus roles de gestión posterior a incidentes o crisis).
- c) Efectuar pruebas de recuperación técnica (garantizando que los sistemas de información puedan ser restablecidos con eficacia).
- d) Realizar ensayos completos probando que la Universidad, el personal, el equipamiento, las instalaciones y los procesos pueden afrontar las interrupciones.

Para las operaciones críticas de la Universidad se deberían tomar en cuenta, además, los siguientes mecanismos:

- a) Efectuar pruebas de recuperación en un sitio alternativo (ejecutando los procesos de las activi-



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

dades de la Universidad en paralelo, con operaciones de recuperación fuera del sitio principal).

b) Realizar pruebas de instalaciones y servicios de proveedores (garantizando que los productos y servicios de proveedores externos cumplan con los compromisos contraídos).

Los planes de continuidad de las actividades de la Universidad deberían ser revisados y actualizados periódicamente, para garantizar su eficacia permanente. Se incluirán procedimientos en el programa de administración de cambios de la Universidad para garantizar que se aborden adecuadamente los tópicos de continuidad de las actividades.

Cada uno de los Responsables de Procesos debería ser el responsable de las revisiones periódicas de cada uno de los planes de continuidad de su incumbencia, como así también de la identificación de cambios en las disposiciones relativas a las actividades de la Universidad aún no reflejadas en dichos planes.

Deberá prestarse atención, especialmente, a los cambios de:

- a) Personal.
- b) Direcciones o números telefónicos.
- c) Estrategia del Organismo.
- d) Ubicación, instalaciones y recursos.
- e) Legislación.
- f) Contratistas, proveedores y clientes críticos.
- g) Procesos, o procesos nuevos / eliminados.
- h) Tecnologías.
- i) Requisitos operacionales.
- j) Requisitos de seguridad.
- k) Hardware, software y otros equipos (tipos, especificaciones, y cantidad).
- l) Requerimientos de los sitios alternativos.
- m) Registros de datos vitales.

Todas las modificaciones efectuadas deberían ser propuestas por el Comité de Seguridad de la información para su aprobación por el superior jerárquico que corresponda. Por otra parte, el resultado de este proceso será dado a conocer a fin de que todo el personal involucrado tenga conocimiento de los cambios incorporados.